

- **Expediente N.º: EXP202212247**

- RESOLUCIÓN DE PROCEDIMIENTO SANCIONADOR

Del procedimiento instruido por la Agencia Española de Protección de Datos y en base a los siguientes

SEGUNDO: Traslado de la reclamación.....	2
TERCERO: Respuesta al traslado de la reclamación.....	3
CUARTO: Realización de actuaciones previas de investigación.....	5
QUINTO: Diligencia AXESOR.....	9
SEXTO: Diligencias Registro Mercantil y AXESOR.....	9
SÉPTIMO: Acuerdo de inicio firmado por la directora de la AEPD.....	10
OCTAVO: Alegaciones de la reclamada de 5/01/2024.....	10
NOVENO: Con fecha de 23/10/2024, se emite propuesta de resolución, del literal: 14	
DÉCIMO: Alegaciones a la propuesta de resolución.....	14
HECHOS PROBADOS.....	16
PRIMERO:.....	16
SEGUNDO:.....	16
TERCERO:.....	16
CUARTO:.....	16
QUINTO:.....	17
SEXTO:.....	17
SÉPTIMO:.....	17
OCTAVO:.....	18
NOVENO:.....	19
DÉCIMO:.....	19
FUNDAMENTOS DE DERECHO.....	19
I Competencia.....	19
II Definición de datos biométricos y de carácter personal.....	19
III Objeto y finalidad del tratamiento.....	27
IV Tratamiento de datos biométricos: legitimación.....	29
V Evaluación de impacto de protección de datos (EIPD).....	31
VI Respuesta a las alegaciones a la infracción del artículo 35 del RGPD.....	37

VII Ejercicio del derecho de acceso y consecuencias de su falta de atención.....	44
VIII Calificación y Tipificación de las infracciones.....	48
IX Determinación de las sanciones.....	49
X Adopción de medidas.....	57
RESUELVE:.....	58

PRIMERO: Presentación de la reclamación

A.A.A. (en adelante, la parte reclamante) con fecha 11/10/2022, interpuso reclamación ante la Agencia Española de Protección de Datos. La reclamación se dirige contra **CARTONAJES BAÑERES, S.A.** con NIF **A03009263** (en adelante, CB). Los motivos en que basa la reclamación son los siguientes:

La parte reclamante manifiesta que CB “realiza una fotografía de la cara de los empleados desde un dispositivo situado en la entrada” y que (...) le indica que esa foto se emplea únicamente para la ficha de los empleados y que, “no se guarda la cara”.

Aporta captura de pantalla de una conversación por WhatsApp, (...), no se aprecia fecha, del siguiente tenor:

- “lo de la ficha ¿es lo de la cara?, porque me gustaría fichar sin datos biométricos. ¿Hay tarjetas o algo así?,

- “No, debe ser la cara,

-...los datos biométricos me generan cierta incomodidad”

- No guarda la cara tranquilo”

Además, el reclamante solicitó el acceso a sus datos personales en fecha 29/08/2022, (con copia de sus datos objeto de tratamiento) especificando fines y categoría de datos, manifestando no haber obtenido respuesta hasta la fecha ni en correo postal ni en el correo electrónico. Se aporta, copia de la solicitud cursada, haciendo constar un correo electrónico: (...), y su dirección en ***DIRECCIÓN.1, “para que se remita a la dirección indicada” como contacto, constando acuse de recibo de CB de 29/08/22. Indica el reclamante que en respuesta a una información “que hago llegar a la empresa, me indica a través de un correo electrónico con fecha 14/09, que están al tanto de mi solicitud de información y que la dirección de CB contactará para dar cumplimiento a su solicitud en relación a la P.D.C.P.” Aporta en documento 3 la copia de dicho correo electrónico desde una dirección (...) y el logo de esa entidad.

Añade el reclamante que no se informa del uso de la imagen.

SEGUNDO: Traslado de la reclamación.

De conformidad con el artículo 65.4 de la Ley Orgánica 3/2018, de 5/12, de Protección de Datos Personales y garantía de los derechos digitales (en adelante LOPDGGDD), se dio

traslado de dicha reclamación a la parte reclamada, para que procediese a su análisis e informase a esta Agencia en el plazo de un mes, de las acciones llevadas a cabo para adecuarse a los requisitos previstos en la normativa de protección de datos.

El traslado, que se practicó conforme a las normas establecidas en la Ley 39/2015, de 1/10, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante, LPACAP), fue recogido en fecha 22/11/2022, como consta en el acuse de recibo que obra en el expediente.

TERCERO: Respuesta al traslado de la reclamación

Con fecha 22/12/2022, se recibe escrito de CB en el que su representante, aporta poder notarial de 7/07/2022, en el que se recoge que: *“comparece la persona designada por **SAICA PACK SL**, domiciliada en Avda. San Juan de la Peña 144, **B50035179**, Zaragoza, como “administradora única en nombre y representación de CB...” que otorga poder a la persona designada como representante de CB, manifestando:*

1) El reclamante fue trabajador de la entidad de ***FECHA.1. Les consta que ejercicio del derecho de acceso, aporta copia (documento 2) en el que firma también el preaviso de baja voluntaria de la empresa el (...), indicando que, respetando el preaviso, su último día de trabajo es el 12/09.

2) *“no obtiene una fotografía de la cara de los empleados desde un dispositivo de la entrada de la compañía, como manifiesta el reclamante”, sino que “Los datos biométricos que se utilizan en la planta se obtienen a través de un dispositivo que sirve para que los empleados fichen a la entrada y salida de las instalaciones. Este dispositivo, no realiza una fotografía de ningún trabajador, sino que realiza una triangulación de ojos-boca-nariz y conteo de píxeles que permiten la identificación de la persona”.*

La entidad manifiesta que *“tras realizar la mencionada triangulación, el sistema remite a una página Excel la confirmación del fichaje del trabajador que contiene únicamente el nombre del trabajador, el día, y la hora, sin guardar ni transferir, dato biométrico alguno.*

“El fichero Excel con dichos datos es la única información que se conserva.”

3) La entidad señala que el trabajador fue informado del tratamiento de sus datos. Aporta copia del documento denominado *“consentimiento e información sobre tratamiento de datos personales de los empleados”*, edición 11/01/2022, firmado por el reclamante el 11/05/2022. Se inicia informando que CB es el responsable del tratamiento, agregando:

- “lea las condiciones y firme el consentimiento”. “En caso de no facilitar su consentimiento expreso CB no podrá tratar sus datos personales para las finalidades recogidas en el mismo. Según el RGPD y la LOPDGDD, con la aceptación de las condiciones del tratamiento de datos personales recogidas en este documento, los interesados prestan su consentimiento expreso para que CB trate los datos facilitados en la ficha del trabajador conforme a las condiciones de tratamiento previamente aceptadas”.

Hay que señalar que en el pie de firma figura *“He leído y acepto las condiciones para el tratamiento de mis datos personales”*.

A modo de apartados, figuran distintos epígrafes, por guardar relación con el objeto laboral se señalan como más significativos, los siguientes:

- *“Finalidad:*

gestionar la relación laboral entre trabajador y CB, como las necesarias para la elaboración del contrato, envío y pago de las nóminas, así como retenciones del IRPF.

Control horario basado en la captación de huella digital del trabajador para el control del cumplimiento de la jornada laboral.”

- *“Legitimación”:* Alude a las disposiciones normativas aplicables en gestión de nóminas y a: *“elaboración de contrato. La comunicación de datos personales es un requisito necesario para poder llevar a cabo el alta del empleado”.*

- *“OBLIGACION DE COMUNICACIÓN”* consta que *“La comunicación de los datos personales es un requisito necesario para poder llevar a cabo el alta del empleado/a, en caso de no dar su consentimiento expreso al tratamiento no podrá realizarse la contratación”*

- *“Categorías de datos”:* Entre otros, destaca: *“imágenes: fotografía-escaneo facial”.*

En el apartado *“derechos”*, se informa entre otros medios de su ejercicio, a través del envío a las oficinas por correo postal o entrega en las oficinas.

La entidad manifiesta que el reclamante fue informado del tratamiento de sus datos, entre ellos de los biométricos, y *“prestó su consentimiento expreso para ello.”*

4) Sobre la base jurídica del tratamiento y la circunstancia que levanta la prohibición para tratar categorías especiales de datos, según el artículo 9 del RGPD y la finalidad del tratamiento, indica CB que aporta *“los ficheros declarados a la AEPD en 2011”*, que trata de un escrito de la AEPD en el que le comunicó el 22/06/2011 la inscripción de ficheros. Señala CB que se correspondería con el denominado *“nóminas, personal y recursos humanos”* constando en finalidad *“recursos humanos, gestión de nóminas, prevención de riesgos laborales, otro tipo de finalidad”* sin que figure en el tipo de datos mención alguna a los de tipo biométrico.

5) En relación a las garantías adecuadas implementadas para la protección de derechos y libertades de las personas, CB aporta escrito de *“política de privacidad”* publicado en su página web que alude a la información que se da a usuarios que proporcionen datos en el sitio web, así como a cuestionarios que se cumplimenten.

En relación con la solicitud de acceso, CB, manifiesta, según la copia que adjuntan en documento 1, le remitieron un correo electrónico desde la entidad denominada SAICA, informando que se ha iniciado su tramitación, y que, en los quince días siguientes a la recepción de la solicitud por el reclamante, se redactaría la contestación a remitir al trabajador. Adjuntan el documento de 15/09/2022, de respuesta que señala en el cuerpo del escrito que se le manda por medio de este burofax en el que le informa de que los datos que figuran en la entidad son los *“básicos de la relación laboral”*.

“nombre, apellidos, dirección, teléfono, DNI, fecha de nacimiento, número de afiliación, para el cumplimiento de las obligaciones laborales.”

No obstante, intentaron conectar para la entrega de la información solicitada tanto telefónicamente como por WhatsApp, sin que acudiera a recogerlo. Por ello, con fecha 9/12/2022, se remitió escrito de contestación a la solicitud de acceso por burofax.

La entidad ha aportado copia del burofax que figura enviado el 9/12/2022.

Se aprecia que el burofax inicia con *“Le damos contestación a su escrito de fecha 29 de agosto del 2022 por medio de este burofax, dado que no pasó a recoger esta comunicación durante el mes de septiembre como usted nos indicó”*. El burofax va dirigido a una dirección diferente a la que el reclamante hizo constar en su solicitud, desconociendo el motivo. Además, no se menciona el dato del reconocimiento facial para el control laboral llevado a cabo.

6) Sobre la Evaluación de Impacto de las operaciones de tratamiento en la protección de datos personales, realizado o motivos por los que no se ha realizado, no se dio respuesta.

7) En relación con las medidas adoptadas para evitar que se produzcan incidencias similares, fechas de implantación y controles para verificar la eficacia, responden que el procedimiento es adecuado, pues *“al contratarse a un trabajador, se recoge el consentimiento informado, indicándole los tratamientos de sus datos”*, y al extinguir la relación, se eliminan los datos.

8) En relación con la decisión adoptada con esta reclamación, señala CB que *“elaboró y comunicó la contestación sobre la reclamación al trabajador y se eliminaron sus datos, salvo los que se han de conservar por Ley”*, y *“respecto sus datos biométricos, fueron borrados del sistema”*.

TERCERO: Admisión a trámite de la reclamación.

Con fecha 11/01/2023, de conformidad con el artículo 65 de la LOPDGDD, se admitió a trámite la reclamación presentada por la parte reclamante.

CUARTO: Realización de actuaciones previas de investigación.

La Subdirección General de Inspección de Datos procedió a la realización de actuaciones previas de investigación para el esclarecimiento de los hechos en cuestión, en virtud de las funciones asignadas a las autoridades de control en el artículo 57.1 y de los poderes otorgados en el artículo 58.1 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), y de conformidad con lo establecido en el Título VII, Capítulo I, Sección segunda, de la LOPDGDD, teniendo conocimiento de los siguientes extremos:

Con fecha 31/05/2023, se realiza una inspección presencial en el establecimiento de CARTONAJES BAÑERES, ubicada en Polígono Industrial Barrio Les Molines, 22, 03450, Banyeres de Mariola, Alicante de la que se desprende:

1. Se manifiesta por los inspeccionados que CARTONAJES BAÑERES, S.A. *“fue adquirida por SAICA PACK S.L. el 7/07/2022”*, entidad con domicilio social en Zaragoza. Se aporta

copia de la escritura notarial de compraventa de acciones nominativas que representan el 98,52% del capital social de CB.

2. Manifiestan los inspeccionados, que con fecha 6/05/2022, se celebró el acta de la constitución del COMITÉ DE DELEGADOS DE PROTECCION DE DATOS del GRUPO SAICA, (CDPD en lo sucesivo). Como reuniones a destacar del CDPD, son señaladas, las de:

- 19/10/2022, en la copia del documento que aporta (acta del CPD de 19/10/2022), en el acuerdo, 7 *“dada la reciente adquisición por parte del grupo SAICA de la entidad CARTONAJES BAÑERES, se acuerda revisar la situación de la citada compañía en lo relativo a la Protección de Datos. Igualmente, se acuerda recomendar a la compañía que proceda de forma inmediata a la sustitución del sistema de fichajes dado que el actual emplea datos biométricos.”*

-20/01/2023, según la copia del documento que aporta (acta del CPD de 20/01/2023 documento 5), en el acuerdo segundo, se recoge: *“orden del día” “adecuación del control e empleados al Reglamento 2016/679 “y que, “se revisan los requerimientos recibidos de la AEPD por la denuncia interpuesta por un antiguo empleado de CB, hoy mercantil del Grupo”, “desde que se adquirió la compañía se está trabajando en la supresión del sistema de identificación actual de los empleados y la implantación de un nuevo sistema que no precise datos biométricos”. “Igualmente consta iniciado el desarrollo de un plan de trabajo nuevo y auditado por tercero independiente para la adecuación de la planta a las exigencias del Reglamento 2016/679”*

También se incluye en el punto tercero, que se acuerda sobre las solicitudes de acceso, que por el Comité se definan aspectos del plazo de respuesta, información que se ha de dar y período que la entidad ha de conservar, a fin de cumplir con las exigencias que la normativa establezca.

3. Aportan copia de:

3.1-documento de abril 23, *“plan de elaboración del RAT y Auditoría RGPD”* para CB, que consiste en una oferta de prestación de servicios referidas a la información, seguridad y protección de datos, firmada por CB el 28/04/2023.

3.2- presupuesto y pedido del nuevo sistema de fichaje de 14/03/2023, asunto *“terminal y tarjetas para nueva planta de SAICA”*, con petición de 175 tarjetas.

3.3- *“Plan de implantación del sistema de fichajes” “plan de integración SAICA CARTONAJES BAÑERES”* fecha inicial 20/03. Figuran las fases de desarrollo: Análisis y diseño, construcción y validación y puesta en productivo con los distintos responsables que las ejecutan y horas totales. La misma hoja en situación a 23 y otro a 25/05/2023. En fecha 29/05 figura *“proyecto finalizado”*.

3.4- *“Comunicación interna del cambio de sistema de fichajes”* de 25/05/2023, en el que se informa que, con fecha 29/05/2023, entrará en funcionamiento el nuevo sistema de fichaje mediante tarjeta individualizada, siguiendo el sistema estándar que se utiliza en todas las plantas del Grupo SAICA. Se recuerda que *“el tratamiento de datos personales de los empleados es necesario para el cumplimiento de una obligación legal derivada del contrato*

de trabajo con finalidad de cumplimiento de la misma y de las obligaciones derivadas de dicha relación laboral.”

A este respecto, el Servicio de Inspección de la Agencia comprueba que, en el momento de la inspección, el reloj para el fichaje solicita una tarjeta identificativa del empleado y una vez realizado el contacto, se debe teclear si es entrada o salida.

3.5-DOCUMENTACIÓN SOBRE “ANTIGUO SISTEMA DE FICHAJES”, titulada “tratamiento biométrico facial”, firmada por la empresa SABACOINSA SL, sin fecha, conteniéndose como destacado:

3.5.1- El “terminal de reconocimiento facial 3D”, era de la marca *****MARCA.1** y utilizaba un lector de reconocimiento facial patentado denominado (...), con tasa de falsa aceptación (FAR false acceptance rate), menor del 0,001%, y una (FRR false rejection rate), menor de 1%, “algoritmo (...)”

3.5.2- En “modo de captación de patrón biométrico”, se indica que: “La captación del patrón biométrico se basa en tomar varias imágenes de la cara y mediante un algoritmo matemático generar un patrón. Este algoritmo de encriptación ((...) algorythm) genera una plantilla representativa de dicho patrón (hash) y se almacena en el equipo y en el software para poder hacer la identificación biométrica”.

Aporta una larga lista de secuencias de números, letras y signos alternados, de lo que sería un “hash (patrón biométrico)”.

3.5.3- “Es imposible obtener la imagen real del rostro con el patrón almacenado en el terminal, ya que no se guarda ninguna imagen del rostro, sino que se establece una relación matemática entre determinados puntos de la misma-singularidades, puntos característicos-dando lugar a un conjunto de números que servirá después para identificar de manera inequívoca a cada persona”.

No es posible obtener la imagen de un rostro con el hash almacenado.

Este procedimiento consiste en la verificación de una persona por un sistema biométrico de comparación con sus datos biométricos adquiridos en el momento de la verificación con un hash almacenado en el equipo. El proceso de búsqueda es de uno-a-uno.”

“el procedimiento está configurado según los criterios establecidos por la Comisión Europea de Protección de Datos que autoriza una verificación/autenticación consistente en la verificación de un individuo por un sistema biométrico en comparación entre sus datos biométricos-adquiridos en el momento de la verificación-con una única plantilla biométrica almacenada en un dispositivo (es decir el proceso de búsqueda de correspondencia uno a uno). Los datos biométricos no se consideran de nivel especial en el caso de que la verificación/autenticación biométrica por plantillas de hash que establezcan verificaciones del hash de uno-a-uno, cumpliendo los criterios de los artículos 6 y 9 del Reglamento General de Protección de Datos.” ...” Nuestro software de gestión PHUC Control almacena el hash (patrón biométrico) que nos proporciona el terminal de reconocimiento facial. Este hash se relaciona con el usuario final con el id de usuario en una tabla especial para los datos biométricos”.

“Los datos biométricos se almacenan en la base de datos propia del software de control horario PHUC Control, ubicada en el servidor en las instalaciones del cliente.”

A este respecto, desde la Inspección de datos se ha comprobado que la empresa SABACOINSA (dirección web phuc.es) cuenta entre sus productos soluciones de reconocimiento facial para el control de presencia de trabajadores.

3. Se plantea por el Servicio de Inspección de la Agencia, que en la documentación aportada a la Agencia en el transcurso de las actuaciones del traslado, AT/04915/2022, se ponía de manifiesto que *“el dispositivo para el fichaje a la entrada y salida de los empleados realiza una “una triangulación de ojos-boca-nariz y conteo de los píxeles que permiten la identificación de la persona, y que una vez realizada la identificación se remite a una página Excel la confirmación del fichaje del trabajador que contiene únicamente el nombre del trabajador, el día, y la hora, sin guardar ni transferir dato biométrico alguno. El fichero con estos datos es la única información que se conserva. Los hashes se almacenaban en el propio sistema de reconocimiento facial.”*

A este respecto, la entidad lo confirma y añade:

a) Ese era el funcionamiento del sistema de fichaje anterior ya que fue desinstalado como consecuencia de la reunión del Comité de Protección de Datos donde se requiere la implantación de un nuevo sistema de fichaje que se realiza en mayo de 2023.

b) Corrigen que el gestor de la base de datos donde se registran los fichajes de los trabajadores es Microsoft Access, no Microsoft Excel como se ha indicado en la documentación.

4. Se plantea por el Servicio de Inspección de la Agencia la manifestación que ya figura de que: *“En caso de baja de un trabajador se elimina el hash del sistema de reconocimiento facial y los datos del fichero Acces de los fichajes se almacenan en un histórico”,* y a este respecto manifiestan que *“todos los fichajes de los trabajadores desde mayo de 2019 se conservan en un histórico al haberse implantado el nuevo sistema de fichaje”,* y que los *“hashes almacenados han sido destruidos”*. Se aporta copia de un certificado de gestión de residuos SM0529 de la empresa WEE INTERNATIONAL RECYCLING SL, de 2/06/2023, indicándose que el 29/05/2023 recibieron en sus instalaciones procedentes de SAICA NATUR unos residuos, concepto *“electrónica de consumo”* y adjunta tres fotografías de lo que parece ser el lector de reconocimiento facial (se puede ver (...)) en la foto de la izquierda), y otros dos elementos, uno de ellos abierto y desarmado.

6. En relación con el derecho de acceso solicitado ante la entidad por *el reclamante*, los representantes de la entidad exponen que se pusieron en contacto con el solicitante por *WhatsApp* para que acudiera a recoger la contestación y posteriormente, *“lo remitieron por fax”*. A este respecto aportan impresión de mensajes de *WhatsApp* mantenidos con el reclamante, en fecha 16/09/2022, según indican para concretar una cita para su recepción. En los mensajes, se puede ver que de lo que se trata es de que se le requiere al reclamante por parte de la empresa para que acuda a la misma a *“firmar una carta en presencia del (...)”* documento que no se define cual es, a pesar de insistir el reclamante que se le envíe antes por correo y en otro mensaje, manifiesta que sí se tratase de la respuesta a su solicitud no necesita que sea por el firmada. Figura referenciado en el documento 14.

7. Se solicita por el Servicio de Inspección de la Agencia el acceso a los datos de fichajes del reclamante, y se verifica que no figura ninguna información.

8. El Servicio de Inspección de la Agencia acompañado del personal inspeccionado, acceden al local donde se encuentra ubicado el sistema de gestión de fichajes de la antigua aplicación con reconocimiento facial, comprobando:

- El local cerrado con llave y dispone de un equipo de videovigilancia y detector de incendios.
- El ordenador donde se encuentra instalada la aplicación está conectado a la Red local y utiliza el sistema operativo Windows 10. El gestor de la base de datos es Microsoft Access.
- La identificación ante el ordenador es a través del código de usuario y contraseña definida en Windows y para el acceso a la aplicación se utiliza también usuario y contraseña, pero distintos al anterior. Únicamente el responsable de recursos humanos (actualmente responsable de producción) y el administrador del Sistema informático disponen de las credenciales de acceso a la aplicación.

Se accede a la aplicación, verificando:

- Se pueden visualizar los fichajes realizados por un usuario y los datos que constan corresponden a fecha y hora de entrada y salida. También figuran los festivos y las ausencias sin especificar el motivo.
- La aplicación dispone de tablas que permiten consultar listados de fichajes de trabajadores con los datos de: nombre y apellidos, número de tarjeta, turnos, calendario y un indicador de estado de baja.
- Los fichajes correspondientes al día 29 y 30/05/2023 figuran como “Ausente”. Los representantes de la entidad manifiestan que es debido a que el reloj asociado a este sistema fue dado de baja el 29/05/2023.

Todo ello figura en documento 13

9. Los representantes de la entidad aportan copia de la siguiente documentación:

- Documento 15, “Política de protección de Datos del Grupo SAICA- v.2 11/04/2022”. Figura en el apartado de “responsable del tratamiento”, que “En este documento, cualquier alusión al responsable vendrá referida a cada una de las sociedades que integran el GRUPO SAICA”, y en introducción consta que el documento tiene la finalidad de “poner en conocimiento del GRUPO SAICA la política interna que este lleva a cabo en cumplimiento del RGPD”

- Documento 16: Management standard de privacidad.

Se adjunta documento con impresión de pantalla de las comprobaciones realizadas

QUINTO: Diligencia AXESOR

Con fecha 6/06/2023, se realizó diligencia del Servicio de Inspección con la información obtenida en MONITORIZA.AXESOR.ES, siguiente:

-De CARTONAJES BAÑERES, en estado activa, domicilio social en Alicante, capital social (...), mismo número de acciones, tipo de empresa “matriz de grupo”, 99 empleados, ventas (...) €.

SEXTO: Diligencias Registro Mercantil y AXESOR

Con fecha 30/08/2023, se obtiene y asocia al expediente:

a) Inscripciones registrales del Registro Mercantil de CARTONAJES BAÑERES, S.A., NIF **A03009263**, figurando activa, y desde 1/08/2022, la inscripción, como ADMINISTRADOR ÚNICO, SAICA PACK SL, publicación 9/08/2022.

b) En axesor.es, informe de CARTONAJES BAÑERES, S.A. con los siguientes datos:

-fecha de constitución 24/06/1957, tipo de empresa: matriz de grupo, estado: activa, capital social: (...)€, tamaño PYME mediana,

- último ejercicio presentado 2021.

-actividad fabricación de papel y cartón ondulados fabricación de envases y embalajes de papel y cartón.

-ventas: (...)€.

-(...).

-cifra de negocios 2021: (...)€.

-valor nominal (...)€.

-figura como administrador único SAICA PACK SL, fecha de nombramiento 1/08/2023.

-empresas filiales y asociadas ELECTRO MARIOLA SL, dos empleados.

a) En axesor.es, informe de SAICA PACK SOCIEDAD LIMITADA NIF: **B50035179**.

-Tipo de Empresa: Filial de grupo.

-Actividad: 1721 - Fabricación de papel y cartón ondulados; fabricación de envases y embalajes de papel y cartón.

-Tamaño: Grande.

-Empresa matriz: SOCIEDAD ANONIMA INDUSTRIAS CELULOSA ARAGONESA, que figura como accionista con participación de 99,99%.

SÉPTIMO: Acuerdo de inicio firmado por la directora de la AEPD.

Con fecha 15/12/2023, la directora de la AEPD acordó:

“INICIAR PROCEDIMIENTO SANCIONADOR a CARTONAJES BAÑERES, S.A., con NIF A03009263, por la presunta infracción del RGPD en los siguientes artículos:

-35, de conformidad con el artículo 83.4.a) del RGPD y a efectos de prescripción de la infracción, calificada como grave en el artículo 73.t) de la LOPDGDD.

-12, de conformidad con el artículo 83.5.b) del RGPD, y a efectos de prescripción de la infracción, calificada como muy grave en el artículo 72.1.k) de la LOPDGDD”

“a los efectos previstos en el art. 64.2 b) de la LPCAPAP, la sanción que pudiera corresponder sería de una multa administrativa de 200.000 euros, por la infracción del artículo 35 del

RGPD, y de una multa administrativa de 20.000 euros por la infracción del artículo 12 del RGPD, sumando un total de 220.000 euros, sin perjuicio de lo que resulte de la instrucción.”

OCTAVO: Alegaciones de la reclamada de 5/01/2024.

1) Manifiesta la reclamada que el sistema de fichajes al que alude la reclamación se instauró en el año 2016, acompaña factura de 14/12/2016-“1 Terminal identificación facial, y 1 Software para control de presencia-PHUC Distribuidor Oficial”. En ese momento no se aplicaba la LOPDGDD ni el RGPD, diferenciando entre la entrada en vigor, a los veinte días de su publicación en el DOUE y su aplicación, a partir del 25/05/2018. “En el momento en que se implantó el sistema de fichajes no resultaba de aplicación dicha norma.”

“En la anterior normativa de aplicación, la LOPD 15/1999, los datos biométricos no se configuraban como especialmente protegidos, ni exigía realizar una EIPD”.

Además, añade que, una vez vigente el RGPD, no es exigible la realización de dicha evaluación de impacto, e inserta un enlace de la AEPD:

(<https://www.aepd.es/preguntas-frecuentes/2-rgpd/10-evaluacion-de-impacto/FAQ-0227-los-tratamientos-iniciados-antes-de-la-aplicacion-del-rgpd-deben-someterse-a-una-evaluacion-de-impacto#:~:text=No%2C%20el%20mandato%20del%20RGPD,comience%20a%20ser%20de%20aplicaci%C3%B3n>)

“Se vulnera el principio de irretroactividad de las disposiciones sancionadoras, art 9.3 de la CE. al sancionar una conducta con una norma que no estaba en vigor en el momento en el que se cometieron los hechos, atendiendo también al artículo 40 de la Ley 40/2015 de 1/10, de régimen jurídico del sector público, LRJSP sobre la aplicación de las disposiciones sancionadoras vigentes en el momento de producirse los hechos”. Pone la reclamada como ejemplo una sentencia de la Audiencia Nacional, de 14/05/2021, de la que no da más detalles que la transcripción de algún párrafo, coincidiendo en tal sentido con la de Sala de lo Contencioso-administrativo, Sección 1ª, Sentencia de 14/05/2021, Rec. 115/2020:

Por tanto, se ha aplicado de manera retroactiva una normativa que no era aplicable cuando acontecieron los hechos sancionados. Debemos añadir que se podía haber aplicado la citada normativa si hubiese sido más favorable - art. 26.2 de la Ley 40/2015, de 1 de octubre-, pero como se señala en la Sentencia del Tribunal Supremo de 30 de octubre de 2009 -recurso nº. 334/2006, F.J.6º-, y, en igual sentido, en las Sentencias de dicho Tribunal de 12 y 26 de noviembre de 2020, recaídas respectivamente, en los recursos números 4.039/2019 y 5.285/2019: “[...] la aplicación retroactiva de la norma más beneficiosa ha de hacerse determinando que disposición es más favorable, mediante el contraste entre ambas, anterior y posterior, consideradas de modo global.... Y dicho contraste, no existe en las resoluciones impugnadas, en las que ni siquiera se hace mención alguna a la Ley Orgánica 15/1999, de 13 de diciembre, y en las que se aplica el RGPD y la Ley Orgánica 3/2018, de 5 de diciembre, como si fuese la normativa que estaba en vigor cuando sucedieron los hechos sancionados, en abril de 2018.”

Entiende la reclamada que es de aplicación esta sentencia, porque en el año 2016 ni el RGPD, ni la LOPDGDD resultaban de aplicación.

Subsidiariamente, manifiesta la reclamada que, dado que la *“instalación del sistema de fichajes tuvo lugar en 2016, la infracción habría prescrito a los dos años, teniendo en cuenta lo señalado en el artículo 73 de la LOPDGDD”*.

2) Considera una falta de proporcionalidad de la sanción el no haber aplicado atenuante alguno. Estima que la afirmación de que *“llegó un momento en que la reclamada determinó que no era adecuado y la mantuvo todavía algunos meses”*, funcionando como agravante, no ha tenido en cuenta que *“con carácter previo a que se iniciara ningún tipo de procedimiento contra la misma, se sustituyó el sistema de fichajes por uno en el que no se efectúa un tratamiento de datos biométricos. Una vez se constató la existencia de un problema respecto del sistema de fichajes, se llevaron a cabo los trámites necesarios para la sustitución del sistema, y la Administración no puede pretender que el cambio fuera de manera inmediata.”*

Añade que el 14/03/2023, se adquirió el sistema nuevo de fichajes, se estableció *“un plan de proyecto para la sustitución del mismo”* folios 335 a 336 del expediente, y a 31/05/2023, en que se produjo la inspección, ya se había sustituido el sistema.

“La sustitución del sistema de fichajes, en ningún caso puede considerarse como una agravante”, estimando en cambio que se tenía que haber aplicado la atenuante del artículo 83.2.f) del RGPD.

-Además, manifiesta la reclamada que CARTONAJES BAÑERES SA fue adquirida por SAICA PACK el 7/07/2022, (98,52% de las acciones) es decir una vez que estaba instalado el sistema de acceso, siendo evidente que la reclamada había llevado a cabo actuaciones para evitar el empleo del sistema instalado, por lo que tampoco se ha aplicado la atenuante del artículo 83.2 b) del RGPD.

-Añade que tampoco se aplica ninguna atenuante de los recogidos en el artículo 76 de la LOPDGDD de los cuales cita:

- el b, por no existir ningún tipo de relación del infractor con la realización de tratamientos de datos personales.
- El c, porque no se ha obtenido beneficio alguno.
- El e, pues si bien no se llevó a cabo un proceso de absorción, sí que se adquirió el 98,52% de las acciones de CARTONAJES BAÑERES.
- El f, no afectó a derechos de menores.

“Al no aplicar ni un solo atenuante vulnera el principio de proporcionalidad”.

-En cuanto a las agravantes aplicadas, indica que comparativamente con otros expedientes sancionadores con el mismo tipo de infracción, se han impuesto sanciones notablemente inferiores y aporta un cuadro de dichos procedimientos, comparando por empleados, cuantía impuesta y atenuantes/agravantes.

202100603, 20.000 asistentes, 200 Mil euros-Agravante: tipo de evento de asistencia masiva.

202209921, 500 trabajadores, 20 MIL euros-Atenuante 76.2.b) (cuando se inició el PS se seguía manteniendo el sistema de fichajes que trataba datos biométricos).

PS/00120/202135, (...), 90 mil trabajadores, incontables clientes y se incluyen menores, 50 MIL euros, “ocho agravantes, UNA atenuante: “No consta reincidencia”.

-También considera que se utiliza un hecho y lo subsume en el tipo, y al mismo tiempo utiliza dicho hecho como circunstancia agravante, ya que estima que concurre negligencia y falta de diligencia por *“haber implantado el sistema y no prever el impacto del mismo”*, que precisamente, eso es lo que se tipifica como infracción, ya que lo que se sanciona es haber efectuado un tratamiento de datos biométricos sin haber efectuado la evaluación de impacto correspondiente.

3-Sobre la infracción del artículo 12 del RGPD, calificada como muy grave en el artículo 72.1k) del RGPD, indica que el mismo texto legal podría calificarse como grave, según el artículo 73.c) de la LOPDGDD *“El impedimento o la obstaculización o la no atención reiterada de los derechos de acceso, “rectificación, supresión, limitación del tratamiento o a la portabilidad de los datos en tratamientos en los que no se requiere la identificación del afectado, cuando este, para el ejercicio de esos derechos, haya facilitado información adicional que permita su identificación.”*

O bien, como leve, en el artículo 74.c) de la LOPDGDD:

“No atender las solicitudes de ejercicio de los derechos establecidos en los artículos 15 a 22 del Reglamento (UE) 2016/679, salvo que resultase de aplicación lo dispuesto en el artículo 72.1.k) de esta ley orgánica.”

“obviándose una serie de circunstancias que no justificarían la tipificación de la infracción como muy grave”:

-con fecha 16/09/2022, *“se le informó” al reclamante que tenía a su disposición la documentación solicitada, y el reclamante indicó que “no tenía problema en acercarse a recoger dicha documentación”.*

-El 19/09/2022, se le remitió un nuevo mensaje para que pasara a recoger la misma, indicando esta vez el reclamante que *“en esos momentos tenía otras prioridades”*, y que por eso no podía acudir.

- Finalmente, *“se le remitió un burofax el 9/12/2022”.*

Manifiesta la reclamada que, *“si se examina la petición puede apreciarse que solamente indica la calle y el número y localidad, sin indicar piso ni puerta, siendo que vivía en un edificio de viviendas, por lo que su dirección era incompleta”, y lo “único que pudieron hacer fue remitirle el burofax a la única dirección válida de la que disponían.”*

Se solicitó en numerosas ocasiones al trabajador que acudiera al domicilio social, con lo que estuvo conforme, nunca acudió. Aun así, se le remitió un burofax a la dirección que disponían, dado que la dirección que había dado era incompleta.

Entiende que no concurre la conducta que se tipifica como muy grave:

-Considera que se vulnera el principio de proporcionalidad, mostrando como ejemplo el PS/369/2022 en que se impone la misma multa, existiendo las siguientes diferencias:

-El caso a comparar contaba con cuatro agravantes, este con dos, aquel, tratando los datos del afectado sin haber sido cliente, allí se valora un atenuante, en este caso ninguna.

-También en esta infracción, la Administración emplea un mismo hecho para tipificar la infracción y para aplicar la circunstancia agravante, ya que se estima que concurre negligencia y falta de diligencia por las citaciones efectuadas por WhatsApp y por el burofax remitido a otra dirección de la indicada, pero a su vez, dichas circunstancias se tienen en cuenta para tipificar la infracción como muy grave y no como grave o leve.

4-Finaliza indicando que, a raíz de lo expuesto, el acuerdo de inicio se ha dictado prescindiendo total y absolutamente del procedimiento legalmente establecido, por lo que procede sea declarado nulo según el artículo 47.1.e) de la LPACAP o subsidiariamente anulable según el artículo 48 de la misma Ley.

NOVENO: Con fecha de 23/10/2024, se emite propuesta de resolución, del literal:

*“PRIMERO: Que por la Directora de la Agencia Española de Protección de Datos se sancione a **CARTONAJES BAÑERES, S.A.**, con NIF **A03009263**, por la infracción del RGPD en sus artículos:*

- 35, de conformidad con el artículo 83.4 a) del RGPD, y a efectos de prescripción de la infracción, calificada como grave en el artículo 73.t) de la LOPDGDD, con 200.000 euros.

- 15, de conformidad con el artículo 83.5 b) del RGPD, y a efectos de prescripción de la infracción, calificada como muy grave en el artículo 72.1.k) de la LOPDGDD, con 20.000

*SEGUNDO: Que por la Directora de la Agencia Española de Protección de Datos se ordene a **CARTONAJES BAÑERES, S.A.**, con NIF **A03009263**, en virtud del artículo 58.2.c) del RGPD, que en el plazo de 30 días desde que la resolución que ponga fin a este procedimiento sea ejecutiva, acredite haber atendido al cumplimiento del ejercicio del derecho de acceso del reclamante.”*

DÉCIMO: Alegaciones a la propuesta de resolución

Con fecha 12/11/2024, se reciben alegaciones a la propuesta de resolución, que, en síntesis, indican:

1-Respecto de la INFRACCIÓN DEL ARTÍCULO 35 DEL RGPD, reitera lo manifestado en las alegaciones precedentes de 5/01/2024. Añade:

- Estima que se yerra en la tipificación por la AEPD, siendo una cosa el hecho de continuar con el empleo de una herramienta de reconocimiento facial, y otra, no haber realizado una EIPD con carácter previo a instalar la herramienta. Reitera sobre esto último, lo ya manifestado en alegaciones al acuerdo de 5/01/2024.

“La AEPD manifiesta que es preciso efectuar una EIPD si se han producido cambios en los riesgos que el tratamiento implica en relación con el momento en que el tratamiento se puso en marcha”, “el hecho de que los datos biométricos formen parte de la categoría especial no implica que se produzca un cambio de riesgo”, pero en este caso:

-Ni se han empleado nuevas tecnologías ni se usan los datos para finalidades distintas, ni se recogen más datos o datos distintos de los que se empleaban.

“En ningún momento se ha acreditado por la Administración actuante que se haya

producido dicho cambio en los riesgos, por lo que es manifiesto que no procede efectuar una EIPD”.

Además, señala que en la propuesta:

- se incide en que “la infracción que se imputa a la entidad mercantil compareciente consistente en no adaptar su comportamiento consistente en efectuar una EIPD”, no está tipificada como infracción. Se ha reformulado la supuesta infracción cometida, indicando: “Por tanto, también es indiscutible que se han venido produciendo tratamiento mediante el uso del sistema biométrico facial establecido por la responsable del tratamiento, CB, tras la entrada en vigor del RGPD a los que la reclamada, no ha adaptado su comportamiento consistente en efectuar una EIPD, como determina el considerando 171 del RGPD y se desprende de los principios y garantías aplicables en el citado RGPD.”

Indica la reclamada que la infracción es “no efectuar una evaluación de impacto en el momento en el que se inicia el tratamiento”, y estima se “está tipificando erróneamente la supuesta infracción cometida”, “ya que dicho precepto no sanciona el no haber adaptado su comportamiento conforme al mentado artículo “.

Añade a su reiteración de la PRESCRIPCIÓN de la infracción, que, si la obligación a haberse realizado nace de la entrada en vigor del RGPD, 25/05/2018, “dies a quo”, “al tener que adaptarse dicho tratamiento a la nueva normativa”, desde la fecha en que se debiera haber cumplido la obligación, se hallaría prescrita la responsabilidad, al haber transcurrido más de dos años a la fecha en que se inicia el acuerdo de inicio, o en otras palabras, el momento de la prescripción “dies ad quem”, sería el 25/05/2020.

-Sobre la PROPORCIONALIDAD, reitera lo manifestado en sus alegaciones precedentes de 5/01/2024, enfatizando que la sustitución del sistema de fichajes antes del inicio de “cualquier procedimiento”, se ha de valorar, y que antes de la Inspección de 31/05/2023, se había adquirido el sistema y una vez adquirida CB el 7/07/2022, “SAICA constató la existencia de un problema respecto del sistema de fichajes”, y estableció el Plan de trabajo para implantar el cambio de sistema, NO PUDIENDO SER UN AGRAVANTE. Debiendo ser el atenuante que señala debe aplicarse, el artículo 83.2.f) del RGPD, que considera no necesita que la medida se tome inmediatamente, sino que lo relevante sería que se ponga remedio a la infracción y se mitiguen los efectos adversos.

Reitera que tampoco se aplica la atenuante del artículo 83.2.b) del RGPD, con base a que cuando se instaló el sistema, la normativa aplicable no exigía la realización de una EIPD, y CB fue adquirida el 7/07/2022, una vez instalado el sistema.

-Añade nuevas resoluciones que sancionan de modo diferente a su caso:

-El expediente 202213792, con tres agravantes, ningún atenuante, y 700 abonados, con 50 MIL euros.

-El expediente 202202960, con dos agravantes y ningún atenuante, y 4125 empleados, con 100 MIL euros.

Considera que la no aplicación de ningún atenuante vulnera el principio de proporcionalidad.

-Frente a la manifestación en la propuesta, de que no cumplió el principio de proactividad al no documentar los motivos por los que no realizó una EIPD, con algún documento pericial

especializado que hubiera extraído tal conclusión, la reclamada manifiesta que ya alegó sus consideraciones sobre la entrada en vigor del RGPD y la implantación del sistema en 2016, y corresponde a la ADMINISTRACION LA CARGA DE LA PRUEBA, pues la presunción de inocencia está garantizada por la Constitución española. Concluye que no efectuó la EIPD porque *“en el año 2016 dicha obligación o se contemplaba en la normativa”*

2-Sobre la infracción del artículo 15 del RGPD, reitera las alegaciones efectuadas con fecha 5/01/2024, aunque continúa refiriéndolas como artículo 12, pidiendo el archivo del procedimiento sancionador.

HECHOS PROBADOS

PRIMERO:

El reclamante fue trabajador de Cartonajes Bañeres (CB) desde ***FECHA.1, fecha en que comunica su baja voluntaria, con efectos 12/09/2022 (último día de trabajo).

SEGUNDO:

Consta recibido por la reclamada el 29/08/2022 la solicitud de ejercicio de derecho de acceso formulada por el reclamante. En la misma figura como datos de contacto a efectos de que se le enviara allí la respuesta, el correo electrónico: (...), y su dirección en *****DIRECCIÓN.1**. El reclamante obtuvo un primer comunicado de la reclamada a través de correo electrónico de 14/09/2022, indicando que se ha iniciado el trámite, pero no recibió respuesta al ejercicio de su derecho. En la petición solicitaba copia de los datos objeto de tratamiento.

TERCERO:

En cuanto a la respuesta al ejercicio del derecho de acceso del reclamante que formula el 29/08/2022, no acredita la reclamada haberlo hecho efectivo, y el reclamante afirmó que no se le ha contestado ni por correo electrónico ni a la dirección postal que consignó en su petición. La reclamada aporta como respuesta, un escrito fechado el 15/09/2022 enviado el 9/12/2022 por burofax a una dirección que no era la que el reclamante hacía constar en su solicitud, en concreto a *****DIRECCIÓN.2**, manifestando la reclamada que lo hizo así, por entender que al no haber más que señalado *****DIRECCIÓN.1**, le faltaba el número del piso y la puerta. A pesar de constar acreditado que personal de la reclamada se comunicó con el reclamante, por WhatsApp el 16 y el 19/09/2022, según impresión de pantalla aportada en actuaciones previas por la reclamada, era, según el literal para que acudiera a firmar una carta en presencia del (...), sin que en modo alguno se trate o sobreentendiera que se refería a la respuesta del derecho ejercicio.

No resulta acreditado que los citados contactos por la reclamada con el reclamante tuvieran como objeto o fin, el de entregar la respuesta al derecho de acceso al reclamante, sino que, sí se acredita que se contactó por dicho medio, pero por otras cuestiones que no acreditan referirse al ejercicio del derecho.

No consta que la reclamada advirtiera al reclamante de la subsanación de su solicitud en modo alguno.

Además, en el escrito que manifiesta la reclamada haber enviado para dar efectividad al derecho, se contiene la referencia genérica al tipo de datos, no a los datos reales, sin mención alguna al reconocimiento facial ni datos inferidos del mismo, registros diarios

producto del control horario laboral diario, ni al derecho a presentar una reclamación ante la autoridad de control.

CUARTO:

La reclamada aportó el 22/12/2022 en su respuesta al traslado, copia del documento: *“consentimiento e información sobre: tratamiento de datos personales de los empleados”* firmado por el reclamante el 11/05/2022. En finalidad, se indicaba que los datos facilitados serán tratados para gestionar la relación laboral, y *“control horario basado en la captación de la huella digital del trabajador para el control del cumplimiento de la jornada laboral”*.

Finaliza: *“He leído y acepto las condiciones para el tratamiento de mis datos personales”, reiterando en su cabecera que “con la aceptación de las condiciones de tratamiento de datos personales recogidas en este documento, los interesados prestan su consentimiento expreso”, y que “caso de no facilitar su consentimiento expreso, CB no podrá tratar sus datos personales para las finalidades recogidas en el mismo”*.

En “*legitimación*” específica, por ejemplo, que la gestión de nóminas responde al cumplimiento de obligación legal, sin que figure referencia alguna a la legitimación del sistema de empleado para el control del cumplimiento de la jornada laboral. El documento no lleva ningún apartado para seleccionar el consentimiento afirmativo, o negarlo, ni opción alguna para revocar el consentimiento, ni en definitiva invitación alguna a aceptar una operación de tratamiento.

QUINTO:

Además, el reclamante señala que, como empleado, la reclamada le obliga a fichar en la entrada del puesto de trabajo con un dispositivo de reconocimiento facial, sin alternativa al uso de otro medio distinto.

SEXTO:

En la respuesta al traslado, el 22/12/2022, CB, respondió, aportando poder notarial de 7/07/2022, de SAICA PACK SL como administradora única de aquella, en su nombre y representación.

En el Registro Mercantil, a 30/08/2023, figura la empresa CB en activo, y desde 1/08/2022 figura inscrito como administrador único SAICA PACK SL

En la visita de inspección realizada por el Servicio de Inspección de la AEPD de 31/05/2023, se presentó por la inspeccionada CB, la información de que CARTONAJES BAÑERES, S.A. *“fue adquirida por SAICA PACK S.L. el 7/07/2022”*, presentando la escritura de compraventa de acciones nominativas que representan el 98,52% del capital social de CB, sin que se desprenda la extinción de la personalidad jurídica de CB.

CB, pasa a pertenecer al GRUPO SAICA, como afirma entre otros, el documento de acta de 19/10/2022 del Comité de Protección de Datos del GRUPO SAICA, constituido el 6/05/2022. En el acta citadas, se discute entre otros, la revisión de la situación de la entidad CB en lo relativo a protección de datos. En sucesivas reuniones posteriores del CPD como la de 20/01/2023 se analiza la situación de CB.

SÉPTIMO:

En la inspección de la AEPD desarrollada el 31/05/2023, además, se aportó por la reclamada el documento que figura referenciado hecho CUARTO, 3.5 *“DOCUMENTACIÓN SOBRE*

ANTIGUO SISTEMA DE FICHAJES", titulado "*tratamiento biométrico facial*", firmado por la empresa SABACOINSA SL, sin fecha, del que se desprende que:

- El sistema utilizaría un terminal de reconocimiento facial 3D, de la marca ***MARCA.1, lector denominado (...). "*La captación del patrón biométrico por parte de la cámara se basa en tomar varias imágenes de la cara y mediante un algoritmo matemático se genera un patrón. Este algoritmo de encriptación genera una plantilla representativa de dicho patrón (hash) y se almacena en EQUIPO y en el SOFTWARE para poder hacer la identificación biométrica*"

- Los datos biométricos se almacenan en la base de datos propia del software de control horario PHUC CONTROL, ubicada en el servidor de las instalaciones del cliente.

- El software de gestión PHUC CONTROL almacena el hash (patrón biométrico) que proporciona el terminal de reconocimiento facial. -Este hash se relaciona con el usuario final con el id de usuario en una tabla especial para los datos biométricos.

Además, la reclamada reconoce:

- Dispone de una base de datos donde se registran los fichajes de los trabajadores gestionada por Microsoft Access.

- Si un trabajador causa baja, se elimina el hash del sistema de reconocimiento facial, y los datos del fichero ACCES de los fichajes se almacenan en un histórico. En caso de que un empleado causara baja en la empresa, el patrón biométrico es eliminado. La reclamada al dejar de utilizar el sistema biométrico de RF para control horario destruyó los patrones biométricos.

- Se acredita que, una vez realizada la identificación, se remite información a una base de datos ACCESS con la confirmación del fichaje del empleado, conteniendo el nombre del trabajador, el día y la hora, que es la información de registro horario que se conserva.

- En el momento de la visita de inspección, 31/05/2023, los datos del registro de fichajes de los trabajadores desde 2019, se conservan en un fichero Access histórico por haberse implantado el nuevo sistema de tarjetas de control laboral diario, y los hash almacenados que servían a ese sistema han sido destruidos. Aporta a tal efecto la reclamada un certificado de eliminación de residuos de 2/06/2023.

La reclamada acredita en alegaciones que el sistema biométrico utilizado para el registro de reconocimiento facial de control horario laboral diario se adquirió el 14/12/2016 con la aportación de la copia de una factura de compra "*Distribuidor PHUC*", sin que en detalle acredite el día de su puesta en práctica.

OCTAVO:

Antes de recibirse el traslado de la reclamación que la AEPD hizo a la reclamada, el COMITÉ DE DELEGADOS DE PROTECCION DE DATOS del GRUPO SAICA, (CDPD), constituido el 6/05/2022, recomendaba en acuerdo de 19/10/2022 a CB, que de forma inmediata se sustituyera el sistema de fichajes de control laboral mediante reconocimiento facial, por emplear datos biométricos).

Consta acreditado que la reclamada siguió utilizando el citado sistema de tratamiento biométrico facial hasta su sustitución efectiva, llevada a efecto el 29/05/2023, figurando registros de horarios laborales de empleados con tal sistema en la base de datos ACCESS de

control horario según se pudo acreditar en actuaciones previas de investigación por el Servicio de Inspección presencial realizada el 31/05/2023, accediendo a la aplicación de control de gestión de fichajes, PHUC control versión registrada.

El mismo CDPD acordó el 20/01/2023, que se estaba adecuando la planta de CB a las exigencias del RGPD, refiriendo expresamente la atención del ejercicio de derechos. Concretamente, en abril 23, se proyectó una auditoría RGPD y elaboración del RAT con oferta de prestación de servicios.

El 20/03/2023, se inició, un plan de implantación de integración de CB, en SAICA del sistema de fichajes finalizando con la distribución de tarjetas a empleados y actualización de tarjetas ID.

A los empleados de CB se les informa del funcionamiento del nuevo sistema de fichaje de control laboral en un documento de 25/05/2023, haciéndoles saber la efectiva implantación desde 29/05/2023 del nuevo sistema de fichaje mediante tarjeta individualizada, similar al del resto de todas las plantas del GRUPO SAICA. El servicio de inspección de la AEPD constató que el sistema de fichaje solicitaba una tarjeta identificativa.

NOVENO:

Sobre la base jurídica del tratamiento y la circunstancia que levanta la prohibición para tratar categorías especiales de datos, según el artículo 9 del RGPD, la reclamada no respondió en el traslado de la reclamación, excusando que había aportado *“los ficheros declarados a la AEPD en 2011”, “nominas, personal y recursos humanos”* y que el reclamante había prestado su consentimiento expreso para el tratamiento de sus datos, entre ellos también para el biométrico *“de la huella dactilar”* para *“control de cumplimiento de jornada laboral”*.

DÉCIMO:

CARTONAJES BAÑERES; (CB) según AXESOR.ES, tiene como objeto social, la fabricación de papel y cartón ondulados, fabricación de envases y embalajes de papel y cartón, fue adquirida el **7/07/2022** por SAICA PACK SL, constando en el Registro Mercantil su publicación como administrador único de CB inscrita el 1/08/2022. En axesor.es, figura de CB, su constitución 24/06/1957, tipo de empresa: matriz de grupo, estado: activa, capital social: (...)€, tamaño PYME mediana, último ejercicio presentado 2021, -ventas: (...)€, (...), -cifra de negocios 2021: (...)€.

FUNDAMENTOS DE DERECHO

I Competencia

De acuerdo con los poderes que el artículo 58.2 del Reglamento (UE) 2016/679 (Reglamento General de Protección de Datos, en adelante RGPD), otorga a cada autoridad de control y según lo establecido en los artículos 47, 48.1, 64.2 y 68.1 de la LOPDGDD, es competente para iniciar y resolver este procedimiento la Directora de la Agencia Española de Protección de Datos.

Asimismo, el artículo 63.2 de la LOPDGDD determina que: *“Los procedimientos tramitados por la Agencia Española de Protección de Datos se regirán por lo dispuesto en el Reglamento (UE) 2016/679, en la presente ley orgánica, por las disposiciones reglamentarias dictadas en*

su desarrollo y, en cuanto no las contradigan, con carácter subsidiario, por las normas generales sobre los procedimientos administrativos."

II Definición de datos biométricos y de carácter personal

Los datos biométricos los define el artículo 4.14 del RGPD:

"datos biométricos»: datos personales obtenidos a partir de un tratamiento técnico específico, relativos a las características físicas, fisiológicas o conductuales de una persona física que permitan o confirmen la identificación única de dicha persona, como imágenes faciales o datos dactiloscópicos;"

Conviene indicar el resto de las definiciones contenidas en el artículo 4 del RGPD:

"1) «datos personales»: toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona;"

2) «tratamiento»: cualquier operación o conjunto de operaciones realizadas sobre datos personales o conjuntos de datos personales, ya sea por procedimientos automatizados o no, como la recogida, registro, organización, estructuración, conservación, adaptación o modificación, extracción, consulta, utilización, comunicación por transmisión, difusión o cualquier otra forma de habilitación de acceso, cotejo o interconexión, limitación, supresión o destrucción;"

(...)

"7) «responsable del tratamiento» o «responsable»: la persona física o jurídica, autoridad pública, servicio u otro organismo que, solo o junto con otros, determine los fines y medios del tratamiento; si el Derecho de la Unión o de los Estados miembros determina los fines y medios del tratamiento, el responsable del tratamiento o los criterios específicos para su nombramiento podrá establecerlos el Derecho de la Unión o de los Estados miembros;"

El ámbito de aplicación del RGPD extiende su protección, tal y como establece su artículo 1.2, a los derechos y libertades fundamentales de las personas físicas y, en particular, su derecho a la protección de los datos personales, definidos en su artículo 4.1 del RGPD. como *"toda información sobre una persona física identificada o identificable («el interesado»); se considerará persona física identificable toda persona cuya identidad pueda determinarse, directa o indirectamente, en particular mediante un identificador, como por ejemplo un nombre, un número de identificación, datos de localización, un identificador en línea o uno o varios elementos propios de la identidad física, fisiológica, genética, psíquica, económica, cultural o social de dicha persona."*

Como ya señaló el Dictamen 4/2007 del grupo de trabajo del artículo 29 (art. 29 de la Directiva 95/46 CE, como organismo de la UE, de carácter consultivo e independiente), sobre

el concepto de datos personales (WP136), de 20/06/2007, los datos biométricos pueden definirse como:

“propiedades biológicas, características fisiológicas, rasgos de la personalidad o tics, que son, al mismo tiempo, atribuibles a una sola persona y mensurables, incluso si los modelos utilizados en la práctica para medirlos técnicamente implican un cierto grado de probabilidad. Ejemplos típicos de datos biométricos son los que proporcionan las huellas dactilares, los modelos retinales, la estructura facial, las voces, pero también la geometría de la mano, las estructuras venosas e incluso determinada habilidad profundamente arraigada u otra característica del comportamiento (como la caligrafía, las pulsaciones, una manera particular de caminar o de hablar, etc.). Una particularidad de los datos biométricos es que se les puede considerar tanto como contenido de la información sobre una determinada persona (Fulano tiene estas huellas dactilares) como un elemento para vincular una información a una determinada persona (este objeto lo ha tocado alguien que tiene estas huellas dactilares y estas huellas dactilares corresponden a Fulano; por lo tanto, Fulano ha tocado este objeto). Como tales, pueden servir de «identificadores». En efecto, al corresponder a una única persona, los datos biométricos pueden utilizarse para identificar a esa persona. Este carácter dual también se da en el caso de los datos sobre el ADN, que proporcionan información sobre el cuerpo humano y permiten la identificación inequívoca de una, y sólo una, persona.”

Se puede afirmar que, desde la identidad biológica, propia de cada persona, se utilizan instrumentos técnicos automatizados que permitirán identificar permanente y unívocamente a todos los individuos, pues todos disponen de dicha identidad biológica (huellas dactilares, cara, voz, iris etc.).

Los datos biométricos cambian irrevocablemente la relación entre el cuerpo y la identidad, ya que hacen que las características del cuerpo humano sean legibles mediante máquinas y estén sujetas a un uso posterior reiterado.

Los datos biométricos presentan la particularidad de ser producidos por el propio cuerpo y lo caracterizan definitivamente, son datos, no sobre esa persona, sino que los datos refieren a la misma persona, en principio no modificables por voluntad del individuo. Además, debido a que los datos biométricos son propios de una persona y perpetuos, el usuario utiliza los mismos datos en diferentes sistemas.

Los datos biométricos pueden tratarse y almacenarse de diferentes formas. A veces, la información biométrica capturada de una persona se almacena y se trata en bruto, lo que permite reconocer la fuente de la que procede sin conocimientos especiales; por ejemplo, la fotografía de una cara, la fotografía de una huella dactilar o una grabación de voz. Otras veces, la información biométrica bruta capturada es tratada de manera que solo se extraen ciertas características o rasgos y se salvan como una plantilla biométrica.

Los sistemas biométricos están estrechamente vinculados a una persona, dado que pueden utilizar una determinada propiedad única de un individuo para su identificación. Cada individuo tiene impresiones dactilares únicas que muestran características específicas que pueden medirse para decidir si una impresión dactilar corresponde con una muestra registrada. Los datos biométricos presentan la particularidad de ser producidos por el propio cuerpo y lo caracterizan definitivamente. Por lo tanto, son únicos, permanentes o definitivos en el tiempo y la persona no puede liberarse de ellos, no se pueden cambiar nunca, ni con la edad, creando cuestiones de responsabilidad en caso de compromiso-pérdida o intrusión en el sistema. A diferencia de una contraseña, en caso de pérdida no se pueden cambiar.

La definición de dato biométrico alude a *“tratamiento técnico”*, sin especificar, excepto para reseñar que el propósito de dicho tratamiento debe ser identificar a una persona.

Para considerarse datos biométricos en el sentido del RGPD, el tratamiento de datos sin procesar, como las características físicas, fisiológicas o conductuales de una persona física deben implicar una medición de dichas características. Así pues, del concepto, no hay que perder de vista:

-La naturaleza de los datos: datos relativos a las características físicas, fisiológicas o conductuales de una persona física;

- Los medios y las formas de tratamiento: datos *“obtenidos a partir de un tratamiento técnico específico”*; lo que las diferencia por ejemplo de las imágenes de una persona que figuran en un sistema de videovigilancia, que no pueden considerarse datos biométricos si no se han tratado técnicamente de una forma específica con el fin de contribuir a la identificación única de esa persona.

Deben ser objeto de *“tratamiento técnico específico”*. Según el WP80 del GT29, adoptado el 1/08/2003 (en adelante, *“WP 80 del GT 29”*), el tratamiento de estos datos se realiza a través de sistemas biométricos que son: *“aplicaciones de las tecnologías biométricas que permiten la identificación automática, y/o la autenticación/comprobación de una persona. Se suelen utilizar aplicaciones de autenticación/comprobación para diversas tareas en campos muy distintos y bajo la responsabilidad de una amplia gama de entidades diferentes.”*

La mención que se incluye en el artículo 4.14 del RGPD como datos biométricos destinadas a que *“permitan”* pueden entenderse a la identificación, la de *“confirmen”* a la verificación.

Para una mayor comprensión, se describen los conceptos de autenticación/verificación e identificación. El Dictamen 3/2012 sobre la evolución de las tecnologías biométricas de 27/04/2012 del Grupo de Trabajo 29, señalaba:-

“-Identificación biométrica: la identificación de un individuo por un sistema biométrico es normalmente el proceso de comparar sus datos biométricos (adquiridos en el momento de la identificación) con una serie de plantillas biométricas almacenadas en una base de datos (es decir, un proceso de búsqueda de correspondencias uno-a-varios).

-Verificación/autenticación biométrica: la verificación de un individuo por un sistema biométrico es normalmente el proceso de comparación entre sus datos biométricos (adquiridos en el momento de la verificación) con una única plantilla biométrica almacenada en un dispositivo (es decir, un proceso de búsqueda de correspondencias uno-a-uno).”

Con leves matices, los conceptos se mencionan en el *“Libro blanco sobre la inteligencia artificial de la Comisión Europea”*, de 19/02/2020, referidos a la imagen facial:

“En lo que se refiere al reconocimiento facial, por «identificación» se entiende que la plantilla de la imagen facial de una persona se compara con otras muchas plantillas almacenadas en una base de datos para averiguar si su imagen está almacenada en ella. La «autenticación» (o «verificación»), por su parte, se refiere habitualmente a la búsqueda de correspondencias

entre dos plantillas concretas. Permite la comparación de dos plantillas biométricas que, en principio, se supone que pertenecen a la misma persona; así, las dos plantillas se comparan para determinar si la persona de las dos imágenes es la misma. Este procedimiento se emplea, por ejemplo, en las puertas de control automatizado de fronteras empleadas en los controles fronterizos de los aeropuertos”.

Las Directrices 5/2022, del Comité Europeo de Protección de Datos (CEPD), sobre el uso de reconocimiento facial en el ámbito de las fuerzas de orden público (véase Versión 2.0, de 26/04/2023), en su apartado 10, señala:

“Como cualquier proceso biométrico, el reconocimiento facial puede cumplir dos funciones distintas:

- La autenticación de una persona con el fin de verificar que dicha persona es quien afirma ser. En este caso, el sistema compara una plantilla o muestra biométrica pregrabada (por ejemplo, almacenada en una tarjeta inteligente o un pasaporte biométrico) con un único rostro, como el de una persona que se presenta en un puesto de control, para verificar si se trata de la misma persona. Por lo tanto, esta función se basa en la comparación de dos plantillas. Se denomina también verificación de 1 a 1.*
- La identificación de una persona con el fin de localizarla entre un grupo de individuos, dentro de un área específica, en una imagen o en una base de datos. En este caso, el sistema debe procesar cada rostro capturado para generar una plantilla biométrica y luego comprobar si coincide con una persona conocida por el sistema. Así pues, esta función se basa en la comparación de una plantilla con una base de datos de plantillas o muestras (base de referencia). Se denomina también identificación de «uno entre muchos». Por ejemplo, puede relacionar un registro de nombres personales (apellidos, nombre) con un rostro, si la comparación se hace con una base de datos de fotografías asociadas a apellidos y nombres. También puede implicar el seguimiento de una persona a través de una multitud, sin establecer necesariamente un vínculo con la identidad civil de la persona.”*

Las citadas Directrices 05/2022, en su apartado 12, indican que el concepto de dato biométrico abarca tanto la “autenticación” como la “identificación”, y si bien son conceptos distintos, en ambos procedimientos se tratan datos dirigidos a identificar de manera unívoca a una persona física, por lo que ambos se incluyen en el concepto de “tratamientos de datos”, y más específicamente, son tratamientos de datos personales de categorías especiales.

En cuanto a la consideración que a la reclamada le merece su sistema biométrico de reconocimiento facial, como se desprende del contenido referido en el HECHO CUARTO/3/3.5/3.5.3/ en el que lo considera como de verificación/autenticación, uno contra uno, se acredita que la comparación entre los datos biométricos de reconocimiento facial empleados por la reclamada es el de identificación, o 1:N, uno versus N, o también denominado uno a varios.

Ello resulta porque los datos adquiridos/entrantes mediante la lectura del rostro cada vez que se accede o se sale para el fichaje, efectuarían un proceso de comparación con los datos de la plantilla, pero no con UNA ÚNICA PLANTILLA BIOMÉTRICA ALMACENADA EN UN DISPOSITIVO, sino con todas las plantillas de todos los empleados -incluida la suya del reclamante- sujetos todos como empleados al sistema de control horario de la reclamada, y previamente recogidas también para ser usadas, almacenadas, TODAS en la base de datos centralizada de la propia reclamada, procediendo, no a cotejo/comparación 1:1, o uno frente a

uno, sino 1, la presentada en ese momento, frente a N o 1 versus varios (todas las almacenadas en la base de datos de la reclamada), para encontrar la suya propia previamente registrada, sin que el empleado disponga en modo alguno de dispositivo de almacenamiento como parece sugerir.

En ambos casos, sea verificación-autenticación, o identificación las técnicas de reconocimiento facial utilizadas se basan en una concordancia estimada entre plantillas: la que se compara y la(s) de referencia. Desde este punto de vista, son técnicas probabilísticas: la comparación deduce una probabilidad mayor o menor de que la persona sea efectivamente quien se ha de autenticar o identificar; si esta probabilidad supera un determinado umbral en el sistema, definido por su usuario o su desarrollador, el sistema entenderá que existe una coincidencia.

Dato de persona física identificada es que esa persona se la distingue o aísla de un grupo de personas. Único, puede referirse a que los datos biométricos tienen tales particularidades que pueden identificar sin ambigüedades a un individuo. De esta forma, a un identificador único, se le puede asociar otros atributos adicionales o datos personales.

Se adelanta, como ya se indicará, que la plantilla biométrica, con propósito de identificación o autenticación es un dato personal per se y un identificador único.

La finalidad del tratamiento: los datos se deben utilizar para la finalidad de identificar de manera unívoca a una persona física.

Las características biométricas se someten a un tratamiento técnico mediante el cual se reconoce a una persona a partir de una imagen o fotografía, que incluye para su puesta en práctica de un proceso cronológico que se contiene en todos los tratamientos de datos biométricos: su captura o registro de datos con su siguiente almacenamiento o procesamiento y la fase de comparación o correspondencia.

Por otro lado, el considerando 51 del RGPD, se refiere a la no consideración sistemáticamente como un tratamiento de categoría especial de datos, a las fotografías, pues únicamente se encuentran comprendidas en la definición de datos biométricos cuando se les aplica un medio de tratamiento técnico específico que *“permita o confirme la identificación única de dicha persona”*. En todo caso, a sensu contrario del citado considerando, sea aplicando a la fotografía un medio de tratamiento técnico específico, o sea con el registro de la cara hecho expreso (por ejemplo, con una cita expresa de CB para la exposición de la cara y la recogida de datos), estaríamos ante datos biométricos.

Todo sistema biométrico para una finalidad, en este caso control laboral del horario, para poder ser usado, ha de registrar antes en el sistema por medio de la captura una serie de parámetros biométricos (la cara en este caso), pues de lo que se trata de conseguir es de realizar un procesamiento sobre esos parámetros del rostro para identificar a la persona cada vez que luego vuelva a entrar y salir por el punto de acceso.

La mecánica de funcionamiento del sistema consiste en que una vez capturada la imagen de la cara y creada la plantilla, esta se almacena para que cuando se pretenda acceder en este caso, al puesto de trabajo, por el espacio determinado por la empleadora, detecta la imagen de la cara y otra vez se procesa, se obtiene una plantilla y se compara con la que se tiene guardada. El espacio físico y soporte en el que se puede guardar la plantilla para poner en marcha la técnica operativa, puede variar, desde la conservación en un dispositivo que solo

se almacena en manos de la persona, mantenido bajo su control exclusivo al portar el usuario (ejemplo una tarjeta) que no es este caso, a una base de datos centralizada en los sistemas de la responsable, como en este caso.

Además, en este caso, junto a las plantillas biométricas almacenadas en el software de gestión, se relacionan con el id de los usuarios (empleados de la empresa) en una tabla específica para datos biométricos, a partir de la que en cada ocasión que se ficha accediendo y saliendo al lugar de trabajo, se genera el registro de control de fichajes, finalidad buscada por la reclamada.

En el denominado proceso de registro están las fases de:

- Registro de los parámetros biométricos. Abarca todos los procesos que se llevan a cabo en un sistema biométrico con el fin de extraer datos biométricos de una fuente biométrica y vincular estos datos a un individuo. En este caso la cara. El software de reconocimiento facial ve el rostro convierte estas medidas en un código numérico, hash o plantilla.

Este código numérico, hash o plantilla, es lo que se guarda para comparar cuando se entra o sale por el espacio donde figura el lector de reconocimiento facial, que registra la entrada o salida de, en este caso acceso a la empresa reclamada, y que sirve como punto de control usado para el registro horario de la jornada. Por ello, las técnicas de reconocimiento facial requieren una cierta cooperación por parte del empleado ya que la cámara debe ser colocada enfrente de la cara mientras se toma la foto.

- Procesamiento: Creando una plantilla con las características personales de los parámetros capturados

- Inscripción: de la plantilla procesada, guardándola en un medio de almacenamiento adecuado. Una vez la inscripción esta completa, el sistema puede empezar a ser usado.

Así pues, la captación presencial ante el dispositivo resulta en la obtención de una imagen, de la que se extraen las características a través del algoritmo, que parte del software del dispositivo de la reclamada.

Algoritmos, que conviene señalar proceden del fabricante o diseñador de dicho dispositivo y del que se considera un factor más de riesgo para el tratamiento, por cuanto la falta de transparencia, tasa de exactitud, su audición, y entidades certificadoras pueden ser factores a tener en cuenta.

Estas características, son las medidas del posicionamiento y mediciones relativas de referencia (puntos nodales distancia: entre los ojos, forma de pómulos...) que recoge de cada imagen en cada individuo y el punto de partida natural para el tratamiento y reconocimiento automático de los individuos. La extracción de características es la que proporciona información para distinguir entre las caras de las diferentes personas según sus variaciones geométricas o fotométricas.

Se reduce la imagen bruta de las características biométricas, en este caso las caras, transformándose, pero conservándose información discriminada destacada que es esencial para el reconocimiento de la persona. Estas características extraídas se mantienen en una plantilla biométrica, que es una forma de representación matemática reducida de la

característica original, denominada aquí por CB como “hash”. La plantilla de referencia se almacena para su comparación, en este caso en una base de datos donde están las de todos los empleados.

En la última fase, se comparará una muestra biométrica-como la cara- presentada al sensor con una plantilla previamente grabada/almacenada. Las fases se avienen con la enumeración de lo que podría ser una operación de tratamiento de datos (recogida, almacenamiento, uso).

En cuanto a que se podría aducir a que solo identifica a los trabajadores pertenecientes al grupo de empleados previamente registrados, no es razón para no considerarse dato biométrico, que están dirigidos a que a las personas físicas se las identifique con los datos generados a partir de la extracción de sus características biométricas.

Además, la definición de datos biométricos incluye que a través del tratamiento técnico específico, “*permitan o confirmen*” “*la identificación única*” de dicha persona. Por tanto, ambas, identificación o autenticación han de ser únicas, referidas a la identificación que se produzca de la persona. La identificación única por otro lado va más allá de que el dato sea de una persona física identificada o identificable. Dato de persona física identificada es que esa persona se la distingue o aísla de un grupo de personas. Único, puede referirse a que los datos biométricos tienen tales particularidades que pueden identificar sin ambigüedades a un individuo. En este caso, la identificación única se produce por el registro de la imagen facial de cada empleado, asociándola a un ID de usuario almacenados en la base de datos de la reclamada, lo que permite identificar a cada empleado.

De acuerdo con la información proporcionada por CB, al pasar por el espacio que recoge la imagen de reconocimiento facial, colocado con el fin del registro horario de entrada y salida, se ha generado “*un número con muchos dígitos*” “mediante la función hash (aplicación de un algoritmo) que proporciona un valor único. Lo que quiere decir es que la información biométrica recogida, en este caso, la imagen de la cara se procesa siguiendo procedimientos definidos en estándares y el resultado de ese proceso se almacena en registros de datos denominados firmas, patrones o “*templates*”. Estos patrones registran numéricamente las características físicas que permiten diferenciar personas. En el espacio de recogida de imagen, el software del dispositivo compara el patrón ofrecido cuando se le presenta con el almacenado, en orden al registro de la jornada.

En este caso, aunque no se guarde enteramente la imagen de la cara, sino una plantilla, todas las plantillas de todos los empleados, cada una de ellas distinta, es capaz de identificar unívocamente a cada empleado al confrontar en el espacio de la toma de la imagen al acceder con el resto de las existentes almacenadas. Las funciones que contiene el algoritmo permiten extraer los puntos característicos para su posterior comparación con una base de datos asociada al conjunto de empleados previamente almacenado, siendo capaz de identificar a su titular de entre todas las plantillas, tratándose datos de carácter personal basados en el procesamiento de la huella, identificando de forma única a dicha persona.

Técnicamente, la plantilla biométrica contra la que se coteja la muestra es el producto de una medición que identifica unívoca y únicamente al individuo.

Los datos biométricos de cada usuario, adquiridos en el momento de su captación y registrados, para someterlos al procedimiento técnico que convierte la imagen, el formato, en muestra biométrica y a través del algoritmo en plantilla biométrica, almacenándose, con objeto de que con las muestras introducidas al colocar el dedo en los accesos, identifique a través

del modelo guardado, de entre todas las plantillas, sin lugar a duda, a su titular, lo que haría, sería, sin lugar a dudas, identificar de forma única a dicha persona.

El uso de la cara no solo es capaz de validar la identidad de forma precisa, sino que tiene información única sobre personas físicas. El algoritmo del software, sobre la muestra biométrica, extrae las características biométricas, reduce y transforma en etiqueta o números esa muestra, constituyendo una representación matemática de la característica biométrica original, que es la plantilla biométrica. La plantilla se almacena para su comparación en la última fase en la cual con la muestra biométrica- en el lector- y con la plantilla previamente grabada, está identificando unívocamente al empleado, en cada ocasión que entra o sale poniendo su cara ante el lector, por lo que se considera que los datos entran dentro del ámbito de los datos especiales, por ser una identificación unívoca.

En el presente caso, desde luego, no puede hablarse de que no se trata información ligada a datos personales de una persona identificada en cada registro de accesos, ya que, además, se debe señalar que si no permitieran la identificación inequívoca del empleado no se produciría el registro horario que tiene como fin.

Queda así, acreditado que CB trata datos personales de carácter biométrico de sus empleados, en este caso con un fin de registro horario que permiten identificar a cada empleado a la hora de entrar o salir a su puesto de trabajo, registrando la jornada diaria, instrumentos técnicos y organizativos dispuestos por la reclamada como responsable de tales tratamientos.

III Objeto y finalidad del tratamiento

Es objeto de valoración en este procedimiento el ajuste normativo que se analiza en cuanto al sistema de reconocimiento facial biométrico facial que CB implantó con la finalidad de tratar los datos de los empleados de su entidad para el registro de la jornada laboral, acceso y salida en el desarrollo del empleo diario.

Dentro del CAPITULO IV del RGPD, se tratan en su Sección 1ª, las obligaciones generales del responsable del tratamiento y del encargado del tratamiento. A tal efecto, el artículo 25 del RGPD señala:”

“1. Teniendo en cuenta el estado de la técnica, el coste de la aplicación y la naturaleza, ámbito, contexto y fines del tratamiento, así como los riesgos de diversa probabilidad y gravedad que entraña el tratamiento para los derechos y libertades de las personas físicas, el responsable del tratamiento aplicará, tanto en el momento de determinar los medios de tratamiento como en el momento del propio tratamiento, medidas técnicas y organizativas apropiadas, como la seudonimización, concebidas para aplicar de forma efectiva los principios de protección de datos, como la minimización de datos, e integrar las garantías necesarias en el tratamiento, a fin de cumplir los requisitos del presente Reglamento y proteger los derechos de los interesados.

2. El responsable del tratamiento aplicará las medidas técnicas y organizativas apropiadas con miras a garantizar que, por defecto, solo sean objeto de tratamiento los datos personales que sean necesarios para cada uno de los fines específicos del tratamiento. Esta obligación se aplicará a la cantidad de datos personales recogidos, a la extensión de su tratamiento, a su plazo de conservación y a su accesibilidad. Tales medidas garantizarán en particular que,

por defecto, los datos personales no sean accesibles, sin la intervención de la persona, a un número indeterminado de personas físicas.”

Ello implica que en el diseño de las operaciones de tratamiento se apliquen esas obligaciones de la protección de datos desde el diseño y por defecto (PDD), *“siendo aplicables durante todo el ciclo de tratamiento, y siendo obligatoria para los sistemas de tratamiento que ya existían antes de que el RGPD entrase en vigor”* (Directrices 4/2019 relativas al artículo 25. Protección de datos desde el diseño y por defecto, adoptadas el 20/10/2020 por el Comité Europeo de Protección de Datos.).

En el mismo sentido: *“37...La naturaleza, el ámbito y el contexto de las operaciones de tratamiento, así como el riesgo, pueden cambiar durante el curso del tratamiento, lo que significa que el responsable deberá reevaluar sus operaciones de tratamiento revisando y valorando periódicamente la efectividad de las medidas y garantías que haya decidido adoptar.*

38. La obligación de mantener, revisar y actualizar la operación de tratamiento, según sea necesario, también se aplica a los sistemas ya existentes. Esto significa que los sistemas heredados que se hayan diseñado antes de la entrada en vigor del RGPD deben someterse a revisión y mantenimiento para asegurar que se aplican medidas y garantías que apliquen los principios y derechos de los interesados de forma efectiva, como se explica en estas Directrices. “

El capítulo III del Real Decreto-ley 8/2019, de 8/03, de medidas urgentes de protección social y de lucha contra la precariedad laboral en la jornada de trabajo incluyó una reforma dirigida a regular el registro de jornada laboral, como forma de combatir la precariedad laboral, y concretamente el art. 10 modifica el Real Decreto Legislativo 2/2015, de 23/10 (ET), Texto Refundido de la Ley del Estatuto de los Trabajadores, (ET) para regular en su artículo 34.9 el registro de jornada, a los efectos de garantizar el cumplimiento de los límites en materia de jornada, de crear un marco de seguridad jurídica tanto para las personas trabajadoras como para las empresas y de posibilitar el control por parte de la Inspección de Trabajo y Seguridad Social. Esta obligación del empleador se impone con una finalidad específica, favorable al trabajador, según se reitera en diversos apartados del Preámbulo. La norma no señala más que la citada obligación, correspondiendo a las entidades instrumentar el modo en que se va a llevar a cabo que debería respetar el marco regulador. El señalado artículo indica:

“La empresa garantizará el registro diario de jornada, que deberá incluir el horario concreto de inicio y finalización de la jornada de trabajo de cada persona trabajadora, sin perjuicio de la flexibilidad horaria que se establece en este artículo.”

Desde dicha implantación, el registro de jornada es una obligación legal impuesta a los empresarios, obligación legal, la del registro, no la del registro mediante reconocimiento facial con registro y lectura biométrica y la reclamada ha manifestado que, no obstante, llevaba utilizándolo desde antes de esta fecha, en concreto desde 2016.

En este caso, se impuso tal cumplimiento mediante el sistema biométrico de reconocimiento facial, que implica un tratamiento de datos personales con la finalidad de constatar el registro del horario laboral diario constatando el *“horario concreto de inicio y finalización de la jornada de trabajo de cada persona trabajadora”*.

CB como responsable del tratamiento, entidad empleadora, fue la que decidió desde un principio, se desconoce la fecha exacta, utilizar el registro y almacenamiento de datos originados por el reconocimiento facial para la finalidad de registro de jornada. Así queda acreditado en hechos probados a través del Servicio de Inspección, que aportó copia del sistema de gestión de empleados.

La entidad SAICA, adquirió la mayor parte de las acciones de la entidad reclamada en 7/07/2022, una vez que el sistema de tratamiento biométrico facial había sido implantado y continuaba funcionando. La entidad CB seguía en activo, si bien se incardinó en el ámbito del GRUPO de empresas SAICA, que impulsó tras su adquisición el desarrollo de decisiones que pudieron afectar a su política de protección de datos como acredita entre otros, el proyecto de abandono del sistema de tratamiento biométrico facial que adopta el 19/10/2022. La exigibilidad de las obligaciones en materia de protección de datos a CB parten del hecho de que su falta de cumplimiento se puede considerar acreditado e imputable, cuanto menos durante el tratamiento de los datos del reclamante, a través del sistema que ella misma impuso, como responsable del tratamiento y el mantenimiento de su personalidad jurídica, lo que supone la plena imputabilidad por su responsabilidad en las acciones que se reprochan y se imputen a dicha entidad.

La obligación del registro de la jornada laboral diaria de los empleados no procede de contrato, sino de una ley, el Estatuto de los Trabajadores, pero no especifica los medios o formas en que se ha de llevar a cabo. Incidiendo ese registro de datos personales con ese fin en un derecho fundamental de sus titulares, el de la protección de sus datos personales, es por lo que cualquier injerencia en los mismos ha de estar prevista expresamente en una Ley.

El análisis de la legitimidad del tratamiento biométrico ha de sustentarse en una base legitimadora, pero también en si el tratamiento es necesario, proporcional y se puede llevar a cabo con un riesgo bajo para los derechos y libertades de los interesados, considerando la norma reguladora que enmarca la obligación.

IV Tratamiento de datos biométricos: legitimación

Los datos biométricos, catalogados como de “*categoría especial*”, en el artículo 9, tanto del RGPD, como de la LOPDGDD, son datos de cuyo uso pueden desprenderse riesgos significativos para los derechos y las libertades fundamentales, y por ello, en principio su tratamiento está prohibido en el artículo 9.1 del RGPD, que indica:

“Quedan prohibidos el tratamiento de datos personales que revelen el origen étnico o racial, las opiniones políticas, las convicciones religiosas o filosóficas, o la afiliación sindical, y el tratamiento de datos genéticos, datos biométricos dirigidos a identificar de manera unívoca a una persona física, datos relativos a la salud o datos relativos a la vida sexual o la orientación sexual de una persona física.”

Similar situación de prohibición se contempla en la Recomendación CM/REC (2015)5, del Comité de Ministros del Consejo de Europa a los Estados miembros sobre el tratamiento de datos personales en el contexto laboral. En concreto, el principio 18 de esta Recomendación establece lo siguiente: “18.1. La recopilación y posterior procesamiento de los datos biométricos solo se debería emprender cuando hay que proteger los intereses legítimos de empresarios, empleados o terceros, solo si no hay otros medios menos intrusivos disponibles y solo si se acompaña de las garantías adecuadas previstas en el principio 21. 18.2. El

tratamiento de los datos biométricos se debe basar en métodos científicamente reconocidos y debe estar sujeto a los requisitos de estricta seguridad y proporcionalidad”.

Respecto a las excepciones que podrían aplicarse en el ámbito de lo laboral que es el aquí afectado, señala el artículo 9 del RGPD:

“2. El apartado 1 no será de aplicación cuando concurra una de las circunstancias siguientes:

...

b) el tratamiento es necesario para el cumplimiento de obligaciones y el ejercicio de derechos específicos del responsable del tratamiento o del interesado en el ámbito del Derecho laboral y de la seguridad y protección social, en la medida en que así lo autorice el Derecho de la Unión o de los Estados miembros”

Estos son requisitos acumulativos con la legitimación prevista en el artículo 6.1 del RGPD, que suponen una garantía adicional en el tratamiento de datos de su titular, que tiene en cuenta que, si la consecución de los fines previstos puede realizarse sin tratamiento de datos personales, será preferible esta vía y supondrá que no es necesario llevar a cabo tratamiento alguno de datos, y subsidiariamente, que la recogida de datos sea necesaria para la finalidad establecida o pretendida y si lo fuera, que sea proporcional.

El Grupo de Trabajo del artículo 29, en su Dictamen 3/2012 sobre la evolución de las tecnologías biométricas, indica que *“Al analizar la proporcionalidad de un sistema biométrico propuesto, es preciso considerar previamente si el sistema es necesario para responder a la necesidad identificada, es decir, si es esencial para satisfacer esa necesidad, y no solo el más adecuado o rentable. Un segundo factor que debe tenerse en cuenta es la probabilidad de que el sistema sea eficaz para responder a la necesidad en cuestión a la luz de las características específicas de la tecnología biométrica que se va a utilizar. Un tercer aspecto para ponderar es si la pérdida de intimidad resultante es proporcional a los beneficios esperados. Si el beneficio es relativamente menor, como una mayor comodidad o un ligero ahorro, entonces la pérdida de intimidad no es apropiada. El cuarto aspecto para evaluar la adecuación de un sistema biométrico es considerar si un medio menos invasivo de la intimidad alcanzaría el fin deseado”.*

Pero tratándose de datos biométricos, además de levantar la prohibición sobre su tratamiento, debe ajustarse a una de las bases jurídicas legitimadoras del tratamiento contenidas en el artículo 6.1 del RGPD. El derecho fundamental a la protección de los datos, previsto en el artículo 18.4 de la CE, se sustenta, por lo que hace al caso, sobre el principio esencial que el tratamiento de datos de su titular, que *“solo será lícito si se cumple al menos una”* de las condiciones que prevé el artículo 6.1.a) a f) del RGPD, partiendo de la base de que cualquier tratamiento de esos datos restringe derechos de su titular por el mero hecho de sufrir dicho tratamiento, momento a partir del cual cada vez va a ser identificado con este mecanismo.

La reclamada alude en su información al reclamado sobre el tratamiento de datos laborales, que la legitimación del tratamiento de sus datos, en el que se incluía el del control horario por *“captación de huella digital”, “imágenes: fotografía-escaneo facial”* que en el procedimiento se ha verificado que se trataba del sistema biométrico de reconocimiento facial, se basa en el cumplimiento y desarrollo de la relación laboral, que se incardinaría en el artículo 6.1.b) del RGPD. Sin embargo, refiriéndonos exclusivamente al tratamiento de datos biométricos del

reconocimiento facial para el control laboral, la reclamada no manifestó aspecto alguno cuando en el trámite de traslado de la reclamación se le cuestionó al respecto. Se ha de tener en cuenta que, de acuerdo con el artículo 9.2.b) del RGPD, se trataría, de:

-que sea “el tratamiento necesario para el cumplimiento de obligaciones y el ejercicio de derechos específicos del responsable del tratamiento o del interesado en el ámbito del Derecho laboral y de la seguridad y protección social”

-“en la medida en que así lo autoricen los Estados Miembros”, que no consta que en el ordenamiento español figure tal disposición autorizadora.

- “o un Convenio Colectivo también con arreglo al derecho de los Estados miembros, que establezca garantías adecuadas del respeto de los derechos fundamentales y de los intereses del interesado.”,

Así pues, también se ha de convenir que la obligación legal del registro de jornada laboral diaria no deriva de obligaciones asumidas entre las partes sino de normativa legal contenida en el artículo 34.9 del ET.

Para el control mediante el registro diario de jornada laboral de cada empleado, es necesario tratar sus datos, siendo diferente el análisis de la necesidad y proporcionalidad en el medio elegido, para lo cual, se podría considerar que existen sistemas alternativos, que alejarían la necesidad y proporcionalidad del tratamiento del reconocimiento facial para este fin, que no se ajustaría a este supuesto de estricta necesidad para llevar a cabo la ejecución del contrato.

Debe considerarse que, en este caso, se ha dejado de utilizar el RF, pasando a un sistema de tarjetas, lo cual puede ser muestra práctica de que era posible otro sistema menos intrusivo en los derechos y con menos riesgos inherentes que se desprenden de la propia naturaleza que conlleva el uso para una actividad ordinaria como es el control horario, dada la entidad de la empresa en la que no se constata existan especiales condiciones de circunstancias que aconsejen ese medio en la empresa reclamada, que utiliza la medida corporal mensurada de forma automatizada para dichos fines.

Como conclusión, si bien el Estatuto de los Trabajadores (“ET”) prevé la posibilidad de que el empresario adopte medidas de vigilancia y control para verificar el cumplimiento de las obligaciones laborales de sus trabajadores (artículo 20.3 del ET), para el caso del control de la jornada, la norma establece la necesidad de elaborar un registro diario de las jornadas. No obstante, la normativa no determina el mecanismo específico a utilizar para el registro de la jornada, ni prevé ninguna autorización expresa para el uso de categorías especiales de datos y, concretamente, de datos biométricos.

En todo caso, en estos tratamientos, se debe ser muy cauteloso en la valoración que se efectúe sobre si se reúnen dichos requisitos, ya que se están tratando datos especiales.

V Evaluación de impacto de protección de datos (EIPD)

Además, el sistema de responsabilidad proactiva implantado por el RGPD, enfocado a la gestión continua de los riesgos potenciales asociados al tratamiento, impone a los responsables del tratamiento que analicen qué datos tratan, con qué finalidades y que tipo de tratamientos llevan a cabo, relacionando los potenciales riesgos a que están expuestos y a

partir de ahí, decidir qué medidas toman y aplican para asegurar su cumplimiento en función de los riesgos detectados y asumidos. Ya se ha mencionado en el fundamento de derecho III que el objeto del tratamiento ha de ir completado con un proceso de PDD.

El tratamiento de RF a través de herramientas biométricas de lectura y registro presenta altos riesgos para los derechos y libertades fundamentales. Antes de implantar un proyecto de tratamiento de datos, siempre y cuando sea probable que el mismo suponga un riesgo significativo para los derechos y libertades de las personas, como es este caso, es preciso auditar su funcionamiento, no de forma aislada sino en el marco del tratamiento concreto en que se va a emplear. La evaluación de impacto en la protección de datos personales, EIPD, es la herramienta que en el RGPD se ocupa de la garantía de cumplimiento de esta vertiente del tratamiento.

En este caso, se han de analizar los riesgos diversos que se pueden dar, incluyendo su tecnología, en el marco de un uso cada vez más intensivo de este tipo de datos. Su uso, interoperabilidad e interconexión tecnológica, es más que probable que interfiera con estos derechos fundamentales y puede dar lugar a cuestionamientos sobre su implantación.

El RGPD establece la obligación de gestionar el riesgo que para los derechos y libertades de las personas supone un tratamiento. Este riesgo surge tanto por la propia existencia del tratamiento, como por las dimensiones técnicas y organizativas del mismo. El riesgo surge por los fines del tratamiento y su naturaleza, y también por su alcance y el contexto en el que se desenvuelve.

La utilización de datos biométricos y, en particular, el procedimiento de reconocimiento facial entraña mayores riesgos para los derechos de los interesados. Es fundamental que el recurso a esas tecnologías se haga respetando debidamente los principios de legalidad, necesidad, proporcionalidad y minimización de los datos establecidos en el RGPD. Si bien el uso de estas tecnologías puede percibirse como particularmente eficaz, los responsables deben, en primer lugar, evaluar el impacto en los derechos y libertades fundamentales y considerar medios menos intrusivos para lograr su objetivo legítimo del tratamiento.

La *“aproximación basada en el riesgo”* se desarrolla en el *“Statement on the role of a risk-based approach in data protection legal frameworks WP218”* del GT 29, WP218, y no es un concepto novedoso en el marco de la protección de datos.

La gestión del riesgo para los derechos y libertades tiene por objetivo el estudio del impacto y la probabilidad de causar daño a las personas, a nivel individual o social, como consecuencia de un tratamiento de datos personales. Por el contrario, la gestión de riesgo de cumplimiento normativo tiene por objetivo facilitar al responsable una herramienta para verificar el grado de cumplimiento de las obligaciones y preceptos exigidos legalmente con relación a una actividad de tratamiento. Por lo tanto, previamente al proceso de gestión de riesgos y como condición sine qua non para emprender una actividad de tratamiento, es preciso sistematizar la verificación de cumplimiento normativo a lo largo de todo el ciclo de vida del tratamiento. La complejidad del proceso de gestión de riesgo ha de ajustarse, no al tamaño de la entidad, la disponibilidad de recursos, la especialidad o sector de la misma, sino al posible impacto de la actividad de tratamiento sobre los interesados y a la propia dificultad del tratamiento.

El artículo 35 del RGPD, establece la obligación de disponer de una Evaluación de Impacto en la Protección de los Datos Personales (EIPD), señalando:

“1. Cuando sea probable que un tipo de tratamiento, en particular si utiliza nuevas

tecnologías, por su naturaleza, alcance, contexto o fines, entrañe un alto riesgo para los derechos y libertades de las personas físicas, el responsable del tratamiento realizará, antes del tratamiento, una evaluación del impacto de las operaciones de tratamiento en la protección de datos personales. Una única evaluación podrá abordar una serie de operaciones de tratamiento similares que entrañen altos riesgos similares.

2. El responsable del tratamiento recabará el asesoramiento del delegado de protección de datos, si ha sido nombrado, al realizar la evaluación de impacto relativa a la protección de datos.

3. La evaluación de impacto relativa a la protección de los datos a que se refiere el apartado 1 se requerirá en particular en caso de:

a) evaluación sistemática y exhaustiva de aspectos personales de personas físicas que se base en un tratamiento automatizado, como la elaboración de perfiles, y sobre cuya base se tomen decisiones que produzcan efectos jurídicos para las personas físicas o que les afecten significativamente de modo similar;

b) tratamiento a gran escala de las categorías especiales de datos a que se refiere el artículo 9, apartado 1, o de los datos personales relativos a condenas e infracciones penales a que se refiere el artículo 10, o

c) observación sistemática a gran escala de una zona de acceso público.

4. La autoridad de control establecerá y publicará una lista de los tipos de operaciones de tratamiento que requieran una evaluación de impacto relativa a la protección de datos de conformidad con el apartado 1. La autoridad de control comunicará esas listas al Comité a que se refiere el artículo 68.

5. La autoridad de control podrá asimismo establecer y publicar la lista de los tipos de tratamiento que no requieren evaluaciones de impacto relativas a la protección de datos. La autoridad de control comunicará esas listas al Comité.

6. Antes de adoptar las listas a que se refieren los apartados 4 y 5, la autoridad de control competente aplicará el mecanismo de coherencia contemplado en el artículo 63 si esas listas incluyen actividades de tratamiento que guarden relación con la oferta de bienes o servicios a interesados o con la observación del comportamiento de estos en varios Estados miembros, o actividades de tratamiento que puedan afectar sustancialmente a la libre circulación de datos personales en la Unión.

7. La evaluación deberá incluir como mínimo:

a) una descripción sistemática de las operaciones de tratamiento previstas y de los fines del tratamiento, inclusive, cuando proceda, el interés legítimo perseguido por el responsable del tratamiento;

b) una evaluación de la necesidad y la proporcionalidad de las operaciones de tratamiento con respecto a su finalidad;

c) una evaluación de los riesgos para los derechos y libertades de los interesados a que se refiere el apartado 1, y

d) las medidas previstas para afrontar los riesgos, incluidas garantías, medidas de seguridad y mecanismos que garanticen la protección de datos personales, y a demostrar la conformidad con el presente Reglamento, teniendo en cuenta los derechos e intereses legítimos de los interesados y de otras personas afectadas.

8. El cumplimiento de los códigos de conducta aprobados a que se refiere el artículo 40 por los responsables o encargados correspondientes se tendrá debidamente en cuenta al evaluar las repercusiones de las operaciones de tratamiento realizadas por dichos responsables o encargados, en particular a efectos de la evaluación de impacto relativa a la protección de datos.

9. Cuando proceda, el responsable recabará la opinión de los interesados o de sus representantes en relación con el tratamiento previsto, sin perjuicio de la protección de intereses públicos o comerciales o de la seguridad de las operaciones de tratamiento.

10. Cuando el tratamiento de conformidad con el artículo 6, apartado 1, letras c) o e), tenga su base jurídica en el Derecho de la Unión o en el Derecho del Estado miembro que se aplique al responsable del tratamiento, tal Derecho regule la operación específica de tratamiento o conjunto de operaciones en cuestión, y ya se haya realizado una evaluación de impacto relativa a la protección de datos como parte de una evaluación de impacto general en el contexto de la adopción de dicha base jurídica, los apartados 1 a 7 no serán de aplicación excepto si los Estados miembros consideran necesario proceder a dicha evaluación previa a las actividades de tratamiento.

11. En caso necesario, el responsable examinará si el tratamiento es conforme con la evaluación de impacto relativa a la protección de datos, al menos cuando exista un cambio del riesgo que representen las operaciones de tratamiento.”

En desarrollo del párrafo 4, la Directora de la AEPD aprobó un listado no exhaustivo, orientativo de los tipos de tratamiento que requieren una evaluación de impacto relativa a la protección de datos, indicándose: *“En el momento de analizar tratamientos de datos será necesario realizar una EIPD en la mayoría de los casos en los que dicho tratamiento cumpla con dos o más criterios de la lista expuesta a continuación, salvo que el tratamiento se encuentre en la lista de tratamientos que no requieren EIPD a la que se refiere en artículo 35.5 del RGPD. La lista se basa en los criterios establecidos por las “DIRECTRICES SOBRE LA EVALUACIÓN DE IMPACTO RELATIVA A LA PROTECCIÓN DE DATOS (EIPD) Y PARA DETERMINAR SI EL TRATAMIENTO «ENTRAÑA PROBABLEMENTE UN ALTO RIESGO» A EFECTOS DEL RGPD”, revisadas por última vez y adoptadas el 4/10/2017, WP 248 rev.01 del GT 29 que los complementa y debe entenderse como una lista no exhaustiva:*

“4. Tratamientos que impliquen el uso de categorías especiales de datos a las que se refiere el artículo 9.1 del RGPD... o deducir información sobre las personas relacionada con categorías especiales de datos.

5. Tratamientos que impliquen el uso de datos biométricos con el propósito de identificar de manera única a una persona física.”

9. Tratamientos de datos de sujetos vulnerables...”

En las mismas Directrices, se señala:

“Con el fin de ofrecer un conjunto más concreto de operaciones de tratamiento que requieran una EIPD debido a su inherente alto riesgo, teniendo en cuenta los elementos particulares del artículo 35, apartado 1, y del artículo 35, apartado 3, letras a) a c), la lista que debe adoptarse a nivel nacional en virtud del artículo 35, apartado 4, y los considerandos 71, 75 y 91, y otras referencias del RGPD a operaciones de tratamiento que «probablemente entrañen un alto riesgo», se deben considerar los nueve criterios siguientes:

“7. Datos relativos a interesados vulnerables (considerando 75): El tratamiento de este tipo de datos representa un criterio debido al aumento del desequilibrio de poder entre los interesados y el responsable del tratamiento, lo cual implica que las personas pueden ser incapaces de autorizar o denegar el tratamiento de sus datos, o de ejercer sus derechos. Entre los interesados vulnerables puede incluirse a niños (se considera que no son capaces de denegar o autorizar consciente y responsablemente el tratamiento de sus datos), empleados”

La EIPD es un paso necesario para el tratamiento de datos, no siendo como se ha descrito, el único exigible. Constituye un presupuesto al que se debe añadir el resto de los requisitos legales para el tratamiento. Entre ellos cabe destacar cuando de un tratamiento de categorías especiales se trate, la concurrencia de una excepción del art. 9.2 del RGPD que levante la prohibición del art. 9.1 del mismo texto legal para tratar categorías especiales de datos personales (en este caso para levantar la prohibición del tratamiento de datos biométrico), además de la base jurídica del artículo 6.1 del RGPD. Además, y en todo caso, habría de cumplirse los principios fundamentales del tratamiento de datos previsto en el artículo 5 del RGPD.

El WP 249, Dictamen 2/2017 sobre el tratamiento de datos en el trabajo, del GT 29 (en adelante, «WP 249 del GT29») al expresar que: *“Independientemente de la base jurídica de dicho tratamiento, antes de su inicio se debe realizar una prueba de proporcionalidad con el fin de determinar si el tratamiento es necesario para lograr un fin legítimo, así como las medidas que deben adoptarse para garantizar que las violaciones de los derechos a la vida privada (...) se limiten al mínimo”*.

Antes de implantar un sistema de RF, el responsable debe de valorar si hay otro sistema menos intrusivo con el que se obtenga idéntica finalidad.

El tratamiento biométrico presenta no solo altos riesgos intrínsecos para los derechos y libertades de los interesados, y así lo ha puesto de manifiesto en las sucesivos dictámenes y Directrices que se han redactado sobre sistemas biométricos por los órganos asesores y consultivos, el Grupo del artículo 29 y desde la entrada en vigor del RGPD por el Comité Europeo de Protección de Datos, sino que conjuga productos tecnológicos utilizados para su funcionamiento, que evolucionan muy rápidamente, influyendo sin duda en las esencias de las operaciones de tratamiento, trasladándose a nuevos escenarios la exposición a los múltiples riesgos que precisan continuas reevaluaciones a los que las organizaciones deben responder a nivel técnico y organizativo.

Entre otros, y sin ser exhaustivo ni pretender un listado cerrado, se pueden mencionar algunos que se contemplan en el Dictamen 3/2012 sobre la evolución de las tecnologías biométricas del GT 29 de 27/04/2012:

-La definición del tamaño (cantidad de información) de la plantilla biométrica es una cuestión crucial. Por una parte, el tamaño de la plantilla debe ser lo bastante grande para gestionar la

seguridad (evitando solapamientos entre los diferentes datos biométricos, o sustituciones de identidad), y por otra, no deberá ser demasiado grande a fin de evitar los riesgos de reconstrucción de los datos biométricos

-Riesgos que conlleva la utilización de datos biométricos para fines de identificación en grandes bases de datos centralizadas, dadas las consecuencias potencialmente perjudiciales para las personas afectadas.

-No hace falta decir que toda pérdida de las cualidades de integridad, confidencialidad y disponibilidad con respecto a las bases de datos sería claramente perjudicial para cualquier aplicación futura basada en la información contenida en dichas bases de datos, y causaría asimismo un daño irreparable a los interesados. Por ejemplo, si los datos registrados de una persona autorizada se asociaran con la identidad de una persona no autorizada, esta última podría acceder a los servicios de que dispone el propietario del dato, sin tener derecho a ello. El resultado sería un robo de identidad, que (independientemente de su detección) quitaría fiabilidad al sistema para futuras aplicaciones y, en consecuencia, limitaría su libertad.

-La transferencia de la información contenida en la base de datos.

-Se puede crear la ilusión de que la identificación a través de la cara siempre es correcta, por ello se debe incluir un análisis de los errores que se pueden producir en su uso, medidores de evaluación del rendimiento, tasa de falsa aceptación- probabilidad de que un sistema biométrico identifique incorrectamente a un individuo o no rechace a un individuo que no pertenece al grupo, y tasa de falso rechazo o falso negativo: no se establece la correspondencia entre una persona y su propia plantilla. Frente a las decisiones que afecten jurídicamente a una persona, toda decisión que se adopte en base a ello, como podría ser en sistemas de registro y control horario, la deducción de retribuciones por registro con el sistema, que solo debería efectuarse salvaguardando los derechos y libertades y los intereses legítimos del interesado, como mínimo el derecho a obtener intervención humana por parte del responsable, a expresar su punto de vista y a impugnar la decisión.

-Vinculación: un gran número de servicios en línea permiten a los usuarios cargar una imagen para vincularla con el perfil del usuario. El RF puede utilizarse para vincular los perfiles de diferentes servicios en línea (a través de la imagen del perfil), pero también entre el mundo en línea y fuera de línea. No está fuera de lo posible tomar una fotografía de una persona en la calle y determinar su identidad en tiempo real buscando en estas imágenes de perfil público. Servicios de terceros también pueden rastrear fotografías de perfil y otras fotografías públicamente disponibles para crear grandes colecciones de imágenes a fin de asociar una identidad del mundo real con tales imágenes. Este impacto aumenta con el creciente despliegue de estas tecnologías. Cada individuo puede figurar en uno o varios sistemas biométricos.

-Deben adoptarse medidas de seguridad con motivo del tratamiento de datos biométricos (almacenamiento, transmisión, extracción de características y comparación, etc.) y sobre todo si el responsable del tratamiento transmite esos datos a través de Internet. Las medidas de seguridad podrían incluir, por ejemplo, la codificación de las plantillas y la protección de las claves de codificación aparte del control del acceso y una protección que convierta en virtualmente imposible la reconstrucción de los datos originales a partir de las plantillas. Adicionalmente, uso de máscaras realistas o de uso de fotos para intentar engañar al sistema, siempre en conexión con los avances y el estado de la técnica., teniendo en cuenta que los

sistemas biométricos más eficaces a la hora de reconocer a una persona son también los más potencialmente vulnerables.

Además, con el desarrollo de las tecnologías, esos riesgos detectados ya entonces se ven incrementados de manera importante

En cuanto a las garantías a implementar que se han de contener en la EIPD, la Guía “*La protección de datos en las relaciones laborales*” de la AEPD contempla, a título de referencia diez aspectos que se pueden tener en cuenta.

Asimismo, el documento de trabajo sobre biometría, adoptado el 1/08/2003 del GT29, opina que los sistemas biométricos relativos a características físicas que no dejan rastro (por ejemplo la forma de la mano, pero no las huellas digitales) o los sistemas biométricos relativos a características físicas que dejan rastro pero no dependen de la memorización de los datos poseídos por una persona distinta del interesado (en otras palabras, los datos no se memorizan en el dispositivo de control de acceso ni en una base de datos central) crean menos riesgos para la protección de los derechos y libertades fundamentales de las personas (Se pueden distinguir los datos biométricos que se tratan de manera centralizada de los datos de referencia biométricos que se almacenan en un dispositivo móvil y el proceso de conformidad se realiza en la tarjeta y no en el sensor o cuando éste forma parte del dispositivo móvil).

-Se acepta generalmente que el riesgo de reutilización de datos biométricos obtenidos a partir de rastros físicos dejados por personas sin darse cuenta (por ejemplo: huellas digitales) para fines incompatibles es relativamente bajo si los datos no están almacenados en bases de datos centralizadas, sino en poder de la persona y son inaccesibles para terceros. El almacenamiento centralizado de datos biométricos incrementa asimismo el riesgo del uso de datos biométricos como llave para interconectar distintas bases de datos, lo cual podría permitir obtener perfiles detallados de los hábitos de una persona tanto a nivel público como privado. Además, la cuestión de la compatibilidad de los fines nos lleva a la interoperabilidad de diferentes sistemas que utilizan la biometría. La normalización que requiere la interoperabilidad puede dar lugar a una mayor interconexión entre bases de datos.

La reclamada no aportó la Evaluación de Impacto del tratamiento de datos biométricos que debería haber superado para llevar a cabo el tratamiento que realizó, susceptible de identificar a cada empleado, ya que tiene su plantilla guardada y cuando presenta la muestra, la comprueba de entre todas las existentes, identificando plenamente a su titular a través de las muestras que se guardan en la base de datos. Como ya se señalado previamente se produce un tratamiento de este tipo de datos.

De conformidad con las evidencias de las que se dispone, se considera que CB incumplió lo establecido en el artículo 35 del RGPD, imputándosele dicha infracción.

VI Respuesta a las alegaciones a la infracción del artículo 35 del RGPD

Con independencia de que el resto de las alegaciones se han respondido en el apartado específico que se pudiera relacionar con las mismas, como en el de determinación de la sanción las relacionadas con la proporcionalidad, aquí se acotan a las relacionadas con la infracción tipificada que se imputa del artículo 35 del RGPD.

Sobre la alegación formulada frente a la propuesta de resolución, relativa a que no cumplió con el principio de responsabilidad proactiva al no documentar los motivos por los que no realizó una EIPD, la reclamada manifiesta que ya alegó sus consideraciones sobre la entrada en vigor del RGPD y la implantación del sistema en 2016, y corresponde a la Administración la carga de la prueba en atención a que la presunción de inocencia está garantizada por la Constitución española. Concluye que no efectuó la EIPD porque *“en el año 2016 dicha obligación no se contemplaba en la normativa”*.

Respecto de la carga de la prueba, cuando el RGPD impone obligaciones al responsable del tratamiento, específicamente, en este caso, referidas a la documentación sobre la no necesidad de tener una EIPD del tratamiento de datos laborales con sistema de reconocimiento facial, se ha de indicar que es a este, al que corresponde acreditar que cumple tales obligaciones.

Ello deriva de lo señalado en el artículo 5.2 del RGPD, que obliga a que los responsables del tratamiento han de demostrar el cumplimiento de sus obligaciones en virtud del RGPD, incluida la eficacia de las medidas, documentando adecuadamente todas las decisiones que adopte al objeto de poder demostrarlo, de conformidad con el considerando 74 del RGPD.

Por ello, el hecho de que la reclamada considere que no ha de llevar a cabo una EIPD, no disminuye la obligación general de los responsables de aplicar medidas para gestionar

adecuadamente los riesgos para los derechos y libertades de los interesados. En la práctica, esto significa que los responsables deben evaluar continuamente los riesgos creados por sus actividades de tratamiento a fin de identificar cuando es probable que un tipo de tratamiento entrañe «un alto riesgo para los derechos y libertades de las personas físicas». Aunque una operación de tratamiento se corresponda con los casos que se haya de efectuar una EIPD, puede que un responsable no considere que dicho tratamiento «entraña probablemente un alto riesgo». En estos casos, el responsable debe justificar y documentar los motivos por los que no se realiza una EIPD e incluir/registrar las opiniones del delegado de protección de datos.

Lo contrario supondría desconocer que el RGPD persigue como objetivos una amplia y reforzada protección del derecho de protección de datos en los derechos de los interesados como de las obligaciones de los responsables del tratamiento como se deduce del considerando 11 del RGPD: *“La protección efectiva de los datos personales en la Unión exige que se refuercen y especifiquen los derechos de los interesados y las obligaciones de quienes tratan y determinan el tratamiento de los datos de carácter personal”*.

En todo caso, y en el supuesto examinado, ha quedado perfectamente probado, en atención a lo constatado en los hechos probados y a lo reconocido por la propia parte reclamada, que ni ha realizado un análisis previo para determinar si tenía que realizar o no una EIPD a partir de mayo de 2018, ni ha realizado una EIPD, desvirtuándose la presunción de inocencia.

Lo que señala en su descargo, respecto de que no han mudado los riesgos, son meras declaraciones de la parte reclamada sin haber realizado un análisis sobre dicho particular, sin elementos claros y documentos que lo sustenten.

Sobre las alegaciones relacionadas con la no exigibilidad de realización de una EIPD porque en el año 2016, cuando se implanta el sistema y se empieza a usar el dato personal biométrico de la huella dactilar, no estaba el RGPD en vigor. Por tanto, no estaba vigente

dicha norma cuando acontecieron los hechos, y se pretende aplicar una norma retroactivamente.

Cita como ejemplo de defensa de su tesis, la sentencia de la Audiencia Nacional, sala de lo contencioso administrativo, sección 1ª de 14/05/2021, rec. 115/2020.

A este respecto, se ha de indicar:

-La sentencia aludida declara la nulidad de la sanción impuesta por la AEPD por infracción muy grave tipificada en el artículo 5.1.f) del RGPD (deber de confidencialidad en el tratamiento de los datos) al considerar que se ha aplicado una normativa que no era aplicable cuando acontecieron los hechos sancionados, 13/04/2018 como es el RGPD.

Cabe citar de la misma:

“fundamento de derecho cuarto”: “el art. 99 del RGPD establece: “1. El presente Reglamento entrará en vigor a los veinte días de su publicación en el Diario Oficial de la Unión Europea.

2. Será aplicable a partir del 25 de mayo de 2018”.

Y, en este sentido, en el considerando 171 del citado RGPD, se dice: “La Directiva 95/46/CE debe ser derogada por el presente Reglamento. Todo tratamiento ya iniciado en la fecha de aplicación del presente Reglamento debe ajustarse al presente Reglamento en el plazo de dos años a partir de la fecha de su entrada en vigor. Cuando el tratamiento se base en el consentimiento de conformidad con la Directiva 95/46/CE, no es necesario que el interesado dé su consentimiento de nuevo si la forma en que se dio el consentimiento se ajusta a las condiciones del presente Reglamento, a fin de que el responsable pueda continuar dicho tratamiento tras la fecha de aplicación del presente Reglamento. Las decisiones de la Comisión y las autorizaciones de las autoridades de control basadas en la Directiva 95/46/CE permanecen en vigor hasta que sean modificadas, sustituidas o derogadas”.

Por tanto, el RGPD entró en vigor a los 20 días de su publicación en el Diario Oficial de la Unión Europea, es decir el 24 de mayo de 2016, sin embargo, sólo será directamente aplicable y obligatorio en todos sus elementos en cada Estado Miembro a partir del 25 de mayo de 2018, disponiendo, por tanto, los Estados Miembros y sus respectivas Autoridades de Control, de un período de 2 años para su preparación, aplicación e interpretación de los distintos derechos y obligaciones que establece.”

La sentencia señala que, a tales hechos, no solo se les aplicó el RGPD, sino también la LOPDGDD que entraba en vigor el 6/12/2018, “por tanto se ha aplicado una normativa que no era aplicable cuando acontecieron los hechos sancionados. Debemos añadir que se podía haber aplicado la citada normativa si hubiese sido más favorable... la aplicación retroactiva de la norma más beneficiosa ha de hacerse determinando qué disposición es más favorable, mediante el contraste entre ambas, anterior y posterior, consideradas de modo global...”. Y dicho contraste, no existe en las resoluciones impugnadas, en las que ni siquiera se hace mención alguna a la Ley Orgánica 15/1999, de 13 de diciembre, y en las que se aplica el RGPD y la Ley Orgánica 3/2018, de 5 de diciembre, como si fuese la normativa que estaba en vigor cuando sucedieron los hechos sancionados, en abril de 2018.”

Como se ve, en primer lugar, se trata del examen de la aplicación de la norma vigente preferente, o si lo fuera, más beneficiosa, en el momento de suceder los hechos, que en principio debería ser la vigente en el momento de producirse el hecho tipificado. Sin embargo,

en este caso, la reclamada excluye de raíz la aplicación del RGPD, añadiendo que la conducta se produjo antes de la entrada en vigor el RGPD, sin explicar que entiende por tal afirmación.

Y, en todo caso, los hechos constitutivos de la infracción y que han sido probados se producen desde la entrada en vigor del RGPD, siendo esta norma de plena aplicación a los mismos.

La reclamación considera el tratamiento efectuado con los datos con fines laborales del reclamante que prestó sus servicios a la reclamada en un período del año 2023, siendo indiscutible que tanto a él, como al resto de empleados se les aplicaba el tratamiento biométrico de reconocimiento facial para el control de jornada diaria. Luego es irrefutable que se producían operaciones diversas y de distinto alcance con tal finalidad sobre los datos de los empleados de la reclamada. A ello, se ha de añadir que cuando cesa el reclamante en su relación laboral, 12/09/2023, al resto de empleados se les siguen tratando estos datos con tales fines hasta el cambio del sistema, día 28/05/2023. Por tanto, también es indiscutible que se han venido produciendo tratamientos de datos mediante el uso del sistema biométrico de reconocimiento facial establecido por la responsable del tratamiento, CB, tras la entrada en vigor del RGPD a los que la reclamada, no ha adaptado su comportamiento, consistente en efectuar una EIPD, como determina el considerando 171 del RGPD y se desprende de los principios, garantías y obligaciones aplicables en el citado RGPD.

El artículo 35 del RGPD indica que antes del inicio de estos tratamientos considerados de alto riesgo, para los derechos y libertades de las personas físicas, es obligatorio realizar una EIPD detallada, con la información que describe el mismo. Ello supone una herramienta esencial para identificar y mitigar riesgos relacionados con el tratamiento y establecer la necesidad y proporcionalidad del tratamiento entre otros elementos comprensivos de la misma.

La declaración sobre el papel de un enfoque basado en el riesgo en la protección de datos, adoptada el 30/05/2014 por el GT 29 indica *“El denominado enfoque basado en el riesgo no es un concepto nuevo, ya que ya es bien conocido en virtud de la actual Directiva 95/46/CE, especialmente en materia de seguridad (artículo 17) y de las obligaciones de control previo de la APD (artículo 20). El régimen jurídico aplicable al tratamiento de categorías especiales de datos (artículo 8) también puede considerarse la aplicación de un enfoque basado en el riesgo: el refuerzo de las obligaciones se deriva de un tratamiento que se considera arriesgado para las personas afectadas. Es importante señalar que, incluso con la adopción de un enfoque basado en el riesgo, no se trata de debilitar los derechos de las personas con respecto a sus datos personales. Estos derechos deben ser tan fuertes, aunque el tratamiento de que se trate sea relativamente «bajo riesgo». Más bien, la escalabilidad de las obligaciones jurídicas basadas en el riesgo aborda los mecanismos de cumplimiento. Esto significa que un responsable del tratamiento cuyo tratamiento es de nivel de riesgo relativamente bajo puede no tener que hacer tanto para cumplir con sus obligaciones legales como un responsable del tratamiento de datos cuyo tratamiento es de alto riesgo.”*

Esta obligación es independiente de otras que se establecen en el citado RGPD. Es claro que la normativa ha evolucionado y el modelo instaurado a nivel de Reglamento europeo de protección de datos, pretende garantizar un elevado nivel de protección de las personas físicas en lo que respecta al tratamiento de sus datos personales.

Lo que persigue el precepto a través de la exigencia de que dicha evaluación se realice previamente al tratamiento es, precisamente, la evaluación de potenciales situaciones de alto

riesgo en los derechos y libertades de los interesados y evitar, en la medida de lo posible, que dichos riesgos se materialicen. Tales riesgos, además, varían con el tiempo, debido a que las circunstancias en las que se producen los tratamientos (contexto, naturaleza, alcance o fines) no permanecen incólumes a lo largo del tiempo. Ello requiere, en consecuencia, una evaluación continua que, por lo que atañe a la EIPD, supone no solo la superación de la misma, sino la realización de actualizaciones periódicas a medida que el contexto, naturaleza, alcance o fines del tratamiento (incluyendo la tipología y número de datos personales tratados) van variando a lo largo del tiempo. Como consecuencia de lo indicado, cada vez que el sistema instaurado por la reclamada realiza las diversas operaciones de tratamiento necesarias para el control laboral horario, se producen una serie de tratamientos de datos, a los que resultaría de aplicación la normativa prevista en el RGPD. Por tanto, aunque el sistema hipotéticamente estuviera operativo desde antes de la entrada en vigor del RGPD, los tratamientos realizados a partir de su entrada en vigor exigen la existencia y superación de la previa evaluación de impacto para que dichos tratamientos sean conformes a esa normativa y a las obligaciones dispuestas en la misma.

Sobre la alegación del enlace que aporta la reclamada, localizado en la web de la Agencia, *“preguntas frecuentes-RGPD-2.10 Evaluación de impacto: Los tratamientos iniciados antes de la aplicación del RGPD ¿deben someterse a una EIPD?”*, recogiendo la información de:

“No, el mandato del RGPD no se extiende a las operaciones de tratamiento que ya estén en curso en el momento en que comience a ser de aplicación. Sin embargo, sí debiera realizarse una Evaluación cuando en una operación iniciada con anterioridad a la aplicación del Reglamento se hayan producido cambios en los riesgos que el tratamiento implica en relación con el momento en que el tratamiento se puso en marcha.

Este cambio en los riesgos puede derivar, por ejemplo, del hecho de que se hayan empezado a aplicar nuevas tecnologías a ese tratamiento, de que los datos se estén usando para finalidades distintas o adicionales a las que se decidieron en su momento, o de que se estén recogiendo más datos, o datos diferentes, de los que en principio se utilizaban para el tratamiento.”

Se debe reseñar que todas las FAQs y las Guías de la AEPD pretenden ser un medio dispuesto para la ciudadanía en general para la concienciación y el conocimiento de las cuestiones relacionadas con la protección de datos, con carácter meramente informativo que no profundizan en el caso o supuestos concretos. Si bien sirve también a los Responsables del tratamiento, y Encargados del tratamiento, pues muchas de ellas van dirigidas a estos intentando facilitarles el cumplimiento de la gestión del cumplimiento normativo, ello no obsta para que el responsable del tratamiento examine en el caso concreto del tratamiento específico que está llevando a cabo cuáles son sus obligaciones en materia de protección de datos.

A mayor abundamiento, si nos fijamos en la respuesta dada por la AEPD a esta pregunta general, esta no es una contestación absoluta, sino que se pone en relación de nuevo con el tratamiento concreto que se está llevando a cabo, en atención a la visión implementada por el RGPD que se basa en los pilares de la responsabilidad proactiva (demostrar que se cumple con el RGPD) y el enfoque de riesgos del tratamiento respecto de los derechos y libertades de los interesados. Si por cualquier causa, incluso otras no previstas como ejemplos en la respuesta, el responsable del tratamiento observa que han existido cambios en los riesgos debe plantearse como mínimo si ha de realizar o no una EIPD, documentando la conclusión alcanzada en todo caso.

Sobre que el tratamiento de datos biométricos de control laboral se inicia en 2016, aportándose la factura de compra, la reclamada además manifestó en la Inspección que los datos recabados para dicho registro de la jornada al amparo del Real Decreto Ley 8/2019 incorporado en el actual artículo 34.9 del Real Decreto Legislativo 2/2015, de 23/10 (ET), Texto Refundido de la Ley del Estatuto de los Trabajadores, (ET), permanecían almacenados en un fichero Acces, histórico, y las plantillas destruidas.

También el Servicio de Inspección accedió al registro de los datos biométricos en su software de gestión de la reclamada, existiendo datos registrados de empleados en abril y mayo 2023, que acreditarían la continuación del uso del sistema hasta su sustitución por el nuevo sistema, en 29/05/2023. Con ello queda claro que los datos, también los del empleado reclamante que estuvo escasamente tres meses ligado por un contrato en 2023, fueron objeto de registro para el control laboral diario utilizando la herramienta de reconocimiento facial, afectando al derecho a la protección de datos no solo del reclamante, sino de todos los empleados, tratamiento continuado durante un amplio ciclo de existencia de los datos, tiempo en el que no se pone en práctica la obligación a cumplir por la reclamada con la entrada en vigor del RGPD, a través de la realización de la EIPD, como se pone de manifiesto por su carencia.

En cuanto a alegación de que la obligación de realizar dicha EIPD estaría prescrita, se ha de indicar que no se computaría el inicio del cómputo de la prescripción de la infracción desde el día en que el sistema se implanta, el año 2016 como pretende la reclamada, pues tal acto no determina más que su puesta en marcha desarrollándose desde entonces la actividad del tratamiento integrada por diversas y reiteradas operaciones de tratamiento con el uso de una tecnología específica hasta el momento de su sustitución por otro sistema basado en tarjetas de fichaje.

La ausencia de dicha obligación comienza desde el día en que debía ser cumplida la obligación dispuesta en el RGPD, mayo de 2018; ausencia de cumplimiento de dicha obligación que se ha mantenido de manera ininterrumpida y como mínimo hasta el día en que se dejó de utilizar el sistema de dicho tipo de registro, 28/05/2023, pues sobre los días 29 y 30, durante la visita de inspección se manifestó que ya no constaban dichos datos registrados debido a la puesta en marcha desde el día 29/05/2023 del nuevo procedimiento de control de fichajes mediante tarjetas.

Es decir, se ha mantenido la falta del cumplimiento de la obligación exigible durante todo ese período, estimando que cada día que el tratamiento de datos se realiza sin una EIPD, el riesgo para los derechos y libertades de las personas afectadas permanece sin evaluar y sin medidas y garantías adecuadas en función de su análisis, prolongando de esta forma la infracción. Nos encontramos, pues, ante una infracción que persiste en el tiempo en tanto no se cumpla con la obligación impuesta en el RGPD. Esto se relaciona con el hecho también acreditado de que pese a exponerse por el órgano técnico especializado de SAICA, el Comité de Protección de Datos que el sistema biométrico de CB debía ser sustituido inmediatamente de octubre 2023, va a ver alargada su aplicación hasta 28/05/2023. En su caso, el citado cómputo de la prescripción de la infracción grave que se considera la del artículo 35 del RGPD, abarcaría en inicio dos años desde el 28/05/2023, considerando que no se hallaría prescrita cuando se inicia el presente procedimiento.

Igualmente, sobre la alegación efectuada a la propuesta de que la exigibilidad de realizar la EIPD antes del tratamiento se debe contar desde la fecha de entrada en vigor del RGPD, se ha de indicar que esta fecha de inicio de cómputo no puede ser considerada, dado que los tratamientos desplegados sobre las personas empleadas por la reclamada continuaron y así se acredita, al menos hasta 28/05/2023, y la obligación de una previa EIPD nunca se ha cumplido tras la entrada en vigor del RGPD. Obligación expresa que no se sana o convalida

por el transcurso del tiempo en tanto haya continuado el tratamiento al que sirve de base. Los datos han sido objeto de tratamiento desde, 2016, hasta 28/05/2023, y si bien la obligación de efectuar la EIPD se produce a partir del 25/05/2018, la obligación de efectuarla no se cumplió, produciéndose la reclamación del reclamante y constatándose la pervivencia de su falta de cumplimiento.

Sobre la alegación en propuesta de que se debe diferenciar la continuación en el uso de la herramienta del hecho de no haber realizado la EIPD con carácter previo a la “*instalación de la herramienta*”, no es lo que se indica en la propuesta, sino que dicha EIPD va cronológicamente “antes del tratamiento efectivo de los datos”, tal como se deduce expresamente del contenido del artículo 35 del RGPD sobre el momento de realizarse: “*Cuando sea probable que un tipo de tratamiento, en particular si utiliza nuevas tecnologías, por su naturaleza, alcance, contexto o fines, entrañe un alto riesgo para los derechos y libertades de las personas físicas, el responsable del tratamiento realizará, antes del tratamiento...*”. En el mismo sentido, al citado tratamiento, le resultarían de aplicación el resto de las exigencias sobre las garantías del tratamiento por diseño, artículo 24.1 del RGPD, pues la gestión del riesgo no puede realizarse de forma aislada, independientemente o después del diseño y/o implementación de un tratamiento. Este tratamiento por diseño, como medida de responsabilidad proactiva, se debe aplicar por el responsable del tratamiento con anterioridad al inicio del tratamiento, y también cuando se esté desarrollando. Se trata de pensar en términos de protección de datos desde el mismo momento en que se diseña un tratamiento que implica el tratamiento de datos personales, de modo que desde el inicio sus responsables deben tomar medidas organizativas y técnicas que permitan aplicar de forma efectiva los principios del RGPD.

Por lo demás, el tratamiento de los datos definido como indica el artículo 4.2 del RGPD, no guarda relación alguna con la instalación de un sistema que le dé soporte, puesto que cuenta en este caso que queda acreditado que el tratamiento de datos con el sistema analizado fue efectivo, y llevado a cabo, y ha transitado al régimen de protección instaurado por una norma de aplicación directa como es el RGPD. La reclamada ha continuado usando en la actividad de tratamiento de control laboral diario, los datos biométricos de sus empleados, realizándose periódicamente tal tipo de tratamientos con la técnica de reconocimiento facial que implica riesgos variados, por lo que el cómputo de inicio de la prescripción no podría contarse desde la instalación del sistema o desde el inicio del uso del mismo.

Sobre la alegación de que los riesgos no han variado desde la instauración del sistema en 2016, se ha de indicar que no se trata de que se conecte el riesgo en el tratamiento de datos solo con la seguridad de los datos o con el daño que se pueda producir, sino con los riesgos en los derechos y libertades fundamentales que implica el tratamiento de los datos con estos sistemas, riesgos inherentes y específicos, así como otros derivados de su implementación al caso concreto, que fue lo que llevó a caracterizarlos desde el RGPD en datos de categoría especial. Además, se ha de tener en cuenta que son los elementos que forman parte del tratamiento de datos, la naturaleza, el ámbito, el contexto y los fines, los que condicionan por otro lado, además de los riesgos, la aplicación de las medidas técnicas y organizativas apropiadas para garantizar su tratamiento.

En todo caso, como ya se ha expresado, los riesgos en los derechos y libertades de las personas físicas derivados de un tratamiento varían o mudan con el tiempo, cuestión que es incontrovertida. La afirmación taxativa de la parte reclamada de que los riesgos en los derechos y libertades de las personas físicas derivados del tratamiento no han variado desde

que se implantó este en 2016, no cuenta con ningún sustento, ningún análisis, ninguna justificación.

Por lo demás, la acreditación del alto riesgo que afecta este sistema de tratamientos no solo se ha contemplado en y desde las primeras directrices y dictámenes sobre estos datos en 2003, Documento de trabajo sobre biometría, de 1/08/2023, continuó en el Dictamen 3/2012 sobre la evolución de las tecnologías biométricas, adoptado el 27/04/2012, y continua contemplándose, como ejemplo de las recientes: Directrices 5/2022 sobre el uso de tecnología de reconocimiento facial en el ámbito de la aplicación de la Ley adoptadas el 26/04/2023, o el Dictamen del CEPD de 11/2024 sobre el uso del reconocimiento facial para racionalizar el flujo de pasajeros, adoptado el 23/05/2024 que ejemplifica los riesgos en los diversos modos de tratar este tipo de datos.

El alto riesgo inherente en el tratamiento de este tipo de datos procede de que los datos biométricos, de la cara en este caso, rasgos fisiológicos son únicos y representan a la misma persona. Además, no plantea los mismos riesgos, por ejemplo, el uso con fines de identificación, en un entorno incontrolado, sin la participación activa de los interesados, donde la plantilla de cada cara que entra en el área de monitoreo se compara con las plantillas de una amplia sección transversal de la población almacenada en una base de datos, planteándose riesgos específicos que deben evaluarse caso por caso.

Por ello, sin perjuicio de que la determinación de los riesgos corresponde a cada responsable del tratamiento en relación con cada uno de sus tratamientos concretos. Parece claro que no es el mismo ni el nivel tecnológico, ni el nivel y sofisticación de posibles ataques ni su nivel de sofisticación o los riesgos de fraude por intrusión en los sistemas, así como los impactos tampoco son los mismos ahora que ocho años atrás. Por otro lado, conocer e identificar las amenazas sobre el uso y el sistema de tratamiento que ha evolucionado y lo sigue haciendo con el transcurso de tiempo, puede ayudar a conocer y minimizar los impactos.

Por lo que se refiere a la afirmación de la entidad reclamada respecto a que no se trataba de un sistema nuevo, conviene señalar que tal circunstancia no exime del cumplimiento de la obligación prevista, una vez la norma desplegó plenos efectos tras su entrada en vigor. Si bien es cierto que la anterior normativa no contemplaba dicha obligación, en la que el foco estaba puesto en la tipología de los datos y no como ahora en los riesgos en los derechos y libertades de los interesados derivados del tratamiento, no es menos cierto que, una vez siendo de aplicación el RGPD, la misma posee plena eficacia. Y que la reclamada, por mor de la responsabilidad proactiva prevista en el art. 5.2 del RGPD, debería no sólo haber realizado y superado una EIPD tal y como se han expuesto en el presente procedimiento, sino que debería de haber determinado también si concurrían las circunstancias previstas del artículo 35 para realizar una EIDP, resultando necesario verificar si en el caso del tratamiento existía una probabilidad de alto riesgo de los derechos y libertades de las personas físicas, en los términos indicados por el mencionado artículo, aunque el tratamiento se hubiera iniciado antes de la aplicación del RGPD. Y ello, debiendo tener en consideración que(i) los riesgos no son estáticos sino dinámicos, que pueden mudar en un tratamiento a lo largo del tiempo, máxime en esta realidad en la que nos encontramos y (ii) que dependen del tratamiento de datos personales concreto que se lleve a cabo y de la propia organización, fines e idiosincrasia del responsable del tratamiento, entre otras cuestiones.

Finalmente, se debe añadir, que no solo los riesgos para los derechos y libertades de los afectados han variado, como muestra que los datos biométricos pasaron en el RGPD a

formar parte de los de categoría especial por los riesgos inherentes que su tratamiento implica para los derechos y libertades de los interesados. A ello, se habrían de sumar las tecnologías automatizadas empleadas a través de algoritmos, la deficiente transparencia de tales medios, amén de la valoración de la necesidad y proporcionalidad en la instauración del sistema, principios que resultan en todo momento aplicables y deben cumplirse.

Por todas estas razones, estas alegaciones no pueden ser atendidas.

VII Ejercicio del derecho de acceso y consecuencias de su falta de atención

El reclamante ejercitó su derecho de acceso el 29/08/2022, estableciéndose las obligaciones en el artículo 12 del RGPD, que señala:

- 1. El responsable del tratamiento tomará las medidas oportunas para facilitar al interesado toda información indicada en los artículos 13 y 14, así como cualquier comunicación con arreglo a los artículos 15 a 22 y 34 relativa al tratamiento, en forma concisa, transparente, inteligible y de fácil acceso, con un lenguaje claro y sencillo, en particular cualquier información dirigida específicamente a un niño. La información será facilitada por escrito o por otros medios, inclusive, si procede, por medios electrónicos. Cuando lo solicite el interesado, la información podrá facilitarse verbalmente siempre que se demuestre la identidad del interesado por otros medios.*
- 2. El responsable del tratamiento facilitará al interesado el ejercicio de sus derechos en virtud de los artículos 15 a 22...*
- 3. El responsable del tratamiento facilitará al interesado información relativa a sus actuaciones sobre la base de una solicitud con arreglo a los artículos 15 a 22, sin dilación indebida y, en cualquier caso, en el plazo de un mes a partir de la recepción de la solicitud..."*
- 4. Si el responsable del tratamiento no da curso a la solicitud del interesado, le informará sin dilación, y a más tardar transcurrido un mes de la recepción de la solicitud, de las razones de su no actuación y de la posibilidad de presentar una reclamación ante una autoridad de control y de ejercitar acciones judiciales.*

Este artículo establece obligaciones generales, comprendido en la sección 1 del capítulo III de dicho Reglamento, relativa en particular al principio de transparencia enunciado en el artículo 5, apartado 1, letra a) del citado Reglamento. Estas obligaciones generales incumben al responsable del tratamiento en lo que respecta a la transparencia de la información y de las comunicaciones, así como a las modalidades de ejercicio de los derechos del interesado.

El artículo 15 del RGPD, incluido en la sección 2 del capítulo III, relativa a la información y al acceso a los datos personales, completa el marco de transparencia del RGPD al conceder al interesado un derecho de acceso a sus datos personales y un derecho de información sobre el tratamiento de dichos datos.

Sobre la atención del derecho de acceso solicitado en 29/08/2022, el citado artículo 15 del RGPD indica su contenido:

“1. El interesado tendrá derecho a obtener del responsable del tratamiento confirmación de si se están tratando o no datos personales que le conciernen y, en tal caso, derecho de acceso a los datos personales y a la siguiente información:

- a) los fines del tratamiento;*
 - b) las categorías de datos personales de que se trate;*
 - c) los destinatarios o las categorías de destinatarios a los que se comunicaron o serán comunicados los datos personales, en particular destinatarios en terceros países u organizaciones internacionales;*
 - d) de ser posible, el plazo previsto de conservación de los datos personales o, de no ser posible, los criterios utilizados para determinar este plazo;*
 - e) la existencia del derecho a solicitar del responsable la rectificación o supresión de datos personales o la limitación del tratamiento de datos personales relativos al interesado, o a oponerse a dicho tratamiento;*
 - f) el derecho a presentar una reclamación ante una autoridad de control;*
 - g) cuando los datos personales no se hayan obtenido del interesado, cualquier información disponible sobre su origen;*
 - h) la existencia de decisiones automatizadas, incluida la elaboración de perfiles, a que se refiere el artículo 22, apartados 1 y 4, y, al menos en tales casos, información significativa sobre la lógica aplicada, así como la importancia y las consecuencias previstas de dicho tratamiento para el interesado.*
- 2. Cuando se transfieran datos personales a un tercer país o a una organización internacional, el interesado tendrá derecho a ser informado de las garantías adecuadas en virtud del artículo 46 relativas a la transferencia.*
- 3. El responsable del tratamiento facilitará una copia de los datos personales objeto de tratamiento. El responsable podrá percibir por cualquier otra copia solicitada por el interesado un canon razonable basado en los costes administrativos. Cuando el interesado presente la solicitud por medios electrónicos, y a menos que este solicite que se facilite de otro modo, la información se facilitará en un formato electrónico de uso común.*
- 4. El derecho a obtener copia mencionado en el apartado 3 no afectará negativamente a los derechos y libertades de otros.”*

Regula el art.15 del RGPD, el derecho denominado *habeas data* o *habeas scriptum*, que consiste en que el afectado puede exigir al responsable del tratamiento una prestación de hacer consistente en la mera exhibición de sus datos.

Se trata de un derecho esencial en la materia que se encuentra recogido en el art.8.b) y c) del Convenio 108 del Consejo de Europa. Por lo demás, es indiscutible que el derecho de acceso constituye núcleo esencial del derecho regulado en el art.18.4 de la Constitución -STC 292/2000 – y que ayudará al solicitante a verificar la legalidad del tratamiento pertinente o a ejercer otros derechos.

Las Directrices 1/2022, del Comité Europeo de Protección de Datos, sobre los derechos de los interesados-derecho de acceso, versión 2.1, adoptada el 28/03/2023 señalan que *“3. En virtud del RGPD, el derecho de acceso consta de tres componentes, es decir, la confirmación de si se tratan o no los datos personales, el acceso a los mismos y la información sobre el tratamiento en sí. El interesado también puede obtener una copia de los datos personales tratados, mientras que esta posibilidad no es un derecho adicional del interesado, sino la modalidad de proporcionar acceso a los datos. Por lo tanto, el derecho de acceso puede entenderse tanto como la posibilidad de que el interesado pregunte al responsable del*

tratamiento si se tratan datos personales sobre él o ella, como la posibilidad de acceder y verificar estos datos. El responsable del tratamiento facilitará al interesado, sobre la base de su solicitud, la información incluida en el ámbito de aplicación del artículo 15, apartados 1 y 2, del RGPD”.

“19. El acceso a los datos personales es el segundo componente del derecho de acceso en virtud del artículo 15, apartado 1, y constituye el núcleo de este derecho. Se refiere a la noción de datos personales tal como se define en el artículo 4, apartado 1, del RGPD. Aparte de los datos personales básicos, como el nombre y la dirección, una variedad ilimitada de datos puede estar incluida en esta definición, siempre que entren en el ámbito material del RGPD, especialmente en lo que respecta a la forma en que se procesan (artículo 2 del RGPD). El acceso a los datos personales significa el acceso a los datos personales reales, no solo una descripción general de los datos ni una mera referencia a las categorías de datos personales tratados por el responsable del tratamiento. Si no se aplican límites o restricciones, los interesados tienen derecho a tener acceso a todos los datos tratados en relación con ellos, o a partes de los datos, en función del alcance de la solicitud (véase sec. 2.3.1). La obligación de facilitar el acceso a los datos no depende del tipo o la fuente de dichos datos. Se aplica en toda su extensión incluso en los casos en que la persona requirente haya facilitado inicialmente los datos al responsable del tratamiento, ya que su objetivo es informar al interesado sobre el tratamiento efectivo de dichos datos por parte del responsable del tratamiento. El alcance de los datos personales en virtud del artículo 15 se explica detalladamente en sec. 4.1 y 4.2”.

34. Cuando los interesados presenten una solicitud de acceso a sus datos, en principio, a información a que se refiere el artículo 15 del RGPD debe facilitarse siempre en su totalidad. En consecuencia, cuando el responsable del tratamiento trate los datos relativos al interesado, el responsable del tratamiento facilitará toda la información a que se refiere el artículo 15, apartado 1, y, en su caso, la información a que se refiere el artículo 15, apartado 2. El responsable del tratamiento debe tomar las medidas adecuadas para garantizar que la información sea completa, correcta y actualizada, lo más cercana posible al estado del tratamiento de datos en el momento de recibir la solicitud. Cuando dos o más responsables del tratamiento traten datos conjuntamente, la disposición de los corresponsables del tratamiento respecto de sus respectivas responsabilidades en relación con el ejercicio de los derechos del interesado, especialmente en lo que respecta a la respuesta a las solicitudes de acceso, no afecta a los derechos de los interesados frente al responsable del tratamiento a quien dirigen su solicitud”.

Como se aprecia, más que la vulneración del principio de tratamiento de datos relacionado con transparencia de datos, que podría suponer relacionarlo con el artículo 12 del RGPD, por el principio de aplicación de especialización de la tipificación a la conducta, resulta más adecuada incluirla en el ámbito de la infracción del artículo 15 del RGPD, de derechos del interesado que todo tratamiento de tales datos debe respetar, dada su especificidad que comprende, en el plazo fijado en el RGPD, contestar al interesado sobre si se están tratando sus datos personales, facilitarle los datos personales reales tratados así como información sobre el tratamiento y sobre los derechos, sin merma de los complementos que perfilan el artículo 12 del RGPD para toda comunicación (lenguaje claro, plazo por citar solo alguno).

Se muda, por tanto, la calificación jurídica de los hechos en esta propuesta de resolución en los términos explicitados. En este sentido, el Tribunal Constitucional ha venido señalando que “el contenido esencial del derecho constitucional a ser informado de la acusación se refiere a los hechos considerados punibles que se imputan al acusado” (STC 95/1995). Por el

contrario, y a diferencia de lo que acontece con los hechos, el TC, en Sentencia 145/1993, advierte que la comunicación al presunto infractor de la calificación jurídica y de la eventual sanción a imponer no integra el contenido esencial del derecho a ser informado de la acusación. Hasta tal punto es importante la puesta en conocimiento de los hechos constitutivos de la infracción administrativa, que el TC ha declarado que las exigencias del artículo 24.2 de la CE se satisfacen fundamentalmente con la sola comunicación de los hechos imputados para poder defenderse sobre los mismos (STC 2/1987 y 190/1987). En esta línea el Tribunal Supremo, Sentencia de 3 de marzo de 2004, señala que *“la finalidad primordial del acuerdo de inicio es informar sobre los hechos imputados y no sobre la calificación jurídica, de lo que se encargará la propuesta de resolución”*.

En este caso, la reclamada no acredita sino haber enviado al solicitante un burofax en 9/12/2022, fuera del plazo establecido para la respuesta en el artículo 12.3 del RGPD a una dirección que no se corresponde con la dirección que el reclamante hizo constar en su solicitud, por lo que el envío carece de eficacia. Alude la reclamada a que no constaba en el domicilio proporcionado más que el número, y ese fue el motivo de enviarlo a otra dirección, que se desconoce de donde o cuando procede o sus fines. Sin embargo, no se remitió al medio alternativo del e mail que se le hizo constar en la petición, y en definitiva no acredita haber llevado a efecto el derecho. Previamente, el 15/09/2022 remitió al reclamante un escrito sin advertir de alguna inconveniencia que ahora manifiesta concurrieron en el derecho ejercitado.

Asimismo, en el contenido de la respuesta, que no recibió en ningún momento el reclamante, se aprecia:

-No basta la mención genérica de los datos de que dispone (nombre y apellidos, DNI, número de afiliación, número de cuenta bancaria, etc., debe identificarlos concretamente, datos reales, no referencia a categoría de datos.

-Omite la referencia al punto 1.f), del artículo 15: *“el derecho a presentar una reclamación ante una autoridad de control;”*

-Omite alusión alguna a los datos tratados en base al reconocimiento facial como categoría de datos, y omite su finalidad pretendida, el cumplimiento de una obligación legal, según la reclamada.

-Omite alusión alguna a los datos derivados, resultantes del reconocimiento facial como pueda ser el listado de asistencia durante la jornada laboral que refleja el marcaje de las jornadas mediante reconocimiento facial al entrar o salir del lugar de trabajo.

En cuanto a las explicaciones de la reclamada que se intentó contactar con el reclamante, con el fin de entregar la respuesta a su petición, como se ha puesto de manifiesto a lo largo del procedimiento, no queda acreditado que ese fuera el fin u objeto de los contenidos de los mensajes de WhatsApp que aluden a que (...) quiere verle y entregarle un documento, a lo que el reclamante indica que se le envíe por correo antes para leerlo y además, que la respuesta a su petición no necesita firma alguna.

La respuesta al ejercicio del derecho de acceso ha de ser proactiva, evaluándose adecuadamente la solicitud y respondiendo sin demora indebida. Al mismo tiempo, el responsable del tratamiento, la reclamada, debe realizar todos los esfuerzos razonables para

asegurarse que se facilita el ejercicio del derecho. A tal efecto, se recuerda que el reclamante también dispuso una dirección e mail propia, en la que la reclamada no consta cursara una copia de su respuesta, ni como se ha reiterado solicitara subsanación al reclamante del domicilio, como manifiesta que lo consideraba erróneo, al no figurar el piso y puerta de la dirección postal.

Por tanto, las alegaciones que pretenden eximir del incumplimiento de esta obligación contenida en el artículo 15 del RGPD no pueden ser atendidas.

VIII Calificación y Tipificación de las infracciones

En cuanto a la infracción del artículo 35 del RGPD, el artículo 83.4 RGPD determina que: *“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 10 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 2 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía:*

“a) las obligaciones del responsable y del encargado a tenor de los artículos 8, 11, 25 a 39, 42 y 43;”

La LOPDGDD establece en su artículo 73.t):

“En función de lo que establece el artículo 83.4 del Reglamento (UE) 2016/679 se consideran graves y prescribirán a los dos años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

t) El tratamiento de datos personales sin haber llevado a cabo la evaluación del impacto de las operaciones de tratamiento en la protección de datos personales en los supuestos en que la misma sea exigible.”

Sobre la alegación formulada tras la propuesta por la reclamada de que se ha variado la tipificación, al figurar en la misma, como *“no adaptar su comportamiento consistente en efectuar una EIPD”*, extrayéndola del literal explicativo que se contiene en la respuesta a su alegación en el apartado de la infracción del artículo 35: *“Por tanto, también es indiscutible que se han venido produciendo tratamientos tras la entrada en vigor del RGPD a los que la reclamada, no ha adaptado su comportamiento consistente en efectuar una EIPD, como determina el considerando 171 del RGPD y se desprende de los principios y garantías aplicables en el citado RGPD.”*, se debe responder que no se ha variado la citada tipificación, según reza el fundamento de derecho VIII, dedicado a la cuestión.

En cuanto a la presunta infracción imputada a la reclamada del artículo 15 del RGD, se encuadraría en el RGPD, artículo 83.5 b) *“Las infracciones de las disposiciones siguientes se sancionarán, de acuerdo con el apartado 2, con multas administrativas de 20 000 000 EUR como máximo o, tratándose de una empresa, de una cuantía equivalente al 4 % como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía”: “los derechos de los interesados a tenor de los artículos 12 a 22”.*

La consideración del derecho de acceso no ha sufrido excesivas modificaciones en su configuración básica en el RGPD y en la LOPDGDD. De acuerdo con entre otras, la Sentencia de la Audiencia Nacional, sala de lo contencioso administrativo, sección 1, recurso

165/2005, de 14/12/2006, se considera que la falta de respuesta al derecho de acceso constituye impedimento u obstaculización en el ejercicio del derecho, convirtiéndose en un derecho ineficaz. Esta interpretación se reitera con posterioridad, entre otras en la SAN sala de lo contencioso administrativo, sección 1, recurso 556/2008 de 18/06/2009.

A efectos de prescripción, la LOPDGDD la encuadra en su artículo 72.1.k), que determina:

“1. En función de lo que establece el artículo 83.5 del Reglamento (UE) 2016/679 se consideran muy graves y prescribirán a los tres años las infracciones que supongan una vulneración sustancial de los artículos mencionados en aquel y, en particular, las siguientes:

“k) El impedimento o la obstaculización o la no atención reiterada del ejercicio de los derechos establecidos en los artículos 15 a 22 del Reglamento (UE) 2016/679.”

IX Determinación de las sanciones

El artículo 58.2 del RGPD, dispone lo siguiente: *“Cada autoridad de control dispondrá de todos los siguientes poderes correctivos indicados a continuación:*

i) imponer una multa administrativa con arreglo al artículo 83, además o en lugar de las medidas mencionadas en el presente apartado, según las circunstancias de cada caso particular;”

La determinación de las sanciones que procede imponer en el presente caso exige observar las previsiones de los artículos 83.1 y 2 del RGPD, preceptos que, respectivamente, disponen lo siguiente:

“1. Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias.”

“2. Las multas administrativas se impondrán, en función de las circunstancias de cada caso individual, a título adicional o sustitutivo de las medidas contempladas en el artículo 58, apartado 2, letras a) a h) y j). Al decidir la imposición de una multa administrativa y su cuantía en cada caso individual se tendrá debidamente en cuenta:

a) la naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o propósito de la operación de tratamiento de que se trate, así como el número de interesados afectados y el nivel de los daños y perjuicios que hayan sufrido;

b) la intencionalidad o negligencia en la infracción;

c) cualquier medida tomada por el responsable o encargado del tratamiento para paliar los daños y perjuicios sufridos por los interesados;

d) el grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32;

- e) *toda infracción anterior cometida por el responsable o el encargado del tratamiento;*
- f) *el grado de cooperación con la autoridad de control con el fin de poner remedio a la infracción y mitigar los posibles efectos adversos de la infracción;*
- g) *las categorías de los datos de carácter personal afectados por la infracción;*
- h) *la forma en que la autoridad de control tuvo conocimiento de la infracción, en particular si el responsable o el encargado notificó la infracción y, en tal caso, en qué medida;*
- i) *cuando las medidas indicadas en el artículo 58, apartado 2, hayan sido ordenadas previamente contra el responsable o el encargado de que se trate en relación con el mismo asunto, el cumplimiento de dichas medidas;*
- j) *la adhesión a códigos de conducta en virtud del artículo 40 o a mecanismos de certificación aprobados con arreglo al artículo 42, y*
- k) *cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción.”*

Dentro de este apartado, la LOPDGDD contempla en su artículo 76, titulado “Sanciones y medidas correctivas”:

“1. Las sanciones previstas en los apartados 4, 5 y 6 del artículo 83 del Reglamento (UE) 2016/679 se aplicarán teniendo en cuenta los criterios de graduación establecidos en el apartado 2 del citado artículo.

2. De acuerdo a lo previsto en el artículo 83.2.k) del Reglamento (UE) 2016/679 también podrán tenerse en cuenta:

- a) El carácter continuado de la infracción.*
- b) La vinculación de la actividad del infractor con la realización de tratamientos de datos personales.*
- c) Los beneficios obtenidos como consecuencia de la comisión de la infracción.*
- d) La posibilidad de que la conducta del afectado hubiera podido inducir a la comisión de la infracción.*
- e) La existencia de un proceso de fusión por absorción posterior a la comisión de la infracción, que no puede imputarse a la entidad absorbente.*
- f) La afectación a los derechos de los menores.*
- g) Disponer, cuando no fuere obligatorio, de un delegado de protección de datos.*
- h) El sometimiento por parte del responsable o encargado, con carácter voluntario, a mecanismos de resolución alternativa de conflictos, en aquellos supuestos en los que existan controversias entre aquellos y cualquier interesado.*

3. Será posible, complementaria o alternativamente, la adopción, cuando proceda, de las restantes medidas correctivas a las que se refiere el artículo 83.2 del Reglamento (UE) 2016/679.”

Para la valoración de la sanción que se implementaría en este acuerdo de inicio, por la

presunta infracción del artículo 35 del RGPD, se contemplan los siguientes factores:

a) *“La naturaleza, gravedad y duración de la infracción, teniendo en cuenta la naturaleza, alcance o el propósito de la operación de tratamiento”*, que era el registro de la jornada diaria laboral y afectaba a toda la plantilla, 99 empleados, que al haberla efectuado sin previa EIPD, supone una naturaleza del tratamiento que implica desequilibrio entre los afectados y el responsable del tratamiento en la relación laboral de control del tiempo trabajado que se establece por norma legal, y que puede llevarse a efecto utilizando otros y diversos medios menos invasivos de la privacidad del empleado que no fueron tenidos en consideración. Asimismo, llegó un momento en que la reclamada a pesar de determinar que no era adecuado, lo mantuvo todavía algunos meses, con lo cual han perdurado los efectos y se agrava la infracción al alargarse el período de tratamiento reiterado que se produce junto con la conservación de los datos en el dispositivo, en la base de datos y en los registros. Todos estos factores operarían como agravantes. (83.2.a RGPD).

Alega la reclamada que no se ha respetado el principio de proporcionalidad de las sanciones, por estimar que debe considerar el cambio del sistema de tratamiento de control laboral diario como atenuante. Como señalan las SSTs, Sala 3ª, de 3/12/2008 (Rec. 6602/2004) y 12/04/2012 (Rec. 5149/2009) es el fundamental que late y preside el proceso de graduación de las sanciones e implica, en términos legales, *“su adecuación a la gravedad del hecho constitutivo de la infracción”* como dispone el artículo 29.3 de la Ley 40/2015, de Régimen Jurídico del Sector Público, dado que toda sanción debe determinarse en congruencia con la entidad de la infracción cometida y según un criterio de proporcionalidad en relación con las circunstancias del hecho. En el RGPD se contiene en el artículo 83.1 que cada autoridad de control garantizará que la imposición de las multas administrativas por las infracciones del mismo sea en cada caso *“individual, efectivas, proporcionadas y disuasorias”*.

Se ha de partir del hecho de que el cambio del sistema de fichajes producido ha supuesto que aun reconociendo en octubre de 2022 que el tratamiento debía cesar inmediatamente, se mantuvo el sistema, lo que implica que se mantuvo el tratamiento de datos sin haber realizado la EIPD, que podría condicionar múltiples aspectos sobre lo que su contenido determinara, especialmente de la necesidad y proporcionalidad del tratamiento y de los riesgos para los derechos y libertades fundamentales de los empleados.

Sobre la alegación de la reclamada de que se debería contar como atenuante sus acciones que condujeron a que cuando se inicia el procedimiento, el sistema ya se había sustituido por el de la tarjeta, ya que no se puede pretender que el cambio fuera de manera inmediata se debe señalar que la misma reclamada manifestó que lleva desde 2016 utilizando la actividad de tratamiento para el control laboral, mediante un sistema que permite la finalidad para la que realiza tratamiento de datos. Trascurrida la entrada en vigor el RGPD sin acometer esta importantísima obligación, continuó sirviendo a los fines establecidos, para el cumplimiento del control horario establecido en la normativa laboral señalada. Desde la entrada en vigor del RGPD los datos biométricos han sido catalogados como datos especiales, y el tratamiento que efectúa la reclamada como responsable del tratamiento implica un alto nivel de riesgo en los derechos y libertades de los afectados en los distintos aspectos referidos a su contenido. Además, se ha de tener en cuenta que la recogida y el tratamiento de datos se produce entre la empresa y empleados, lo que implica un contexto de desequilibrio de poder entre las partes, asociado a la deficiente información del tratamiento de sus datos, al indicarse que tenía que otorgar el consentimiento expreso para el tratamiento de sus datos, incluyendo los de reconocimiento facial, cuando no se le daba otra opción. Adicionalmente, en la otra

infracción, la reclamada tuvo conocimiento de los hechos con el traslado de la reclamación, y no consta su puesta al día atendiendo el derecho del reclamante

Finalmente, si bien cuando se efectúa la visita de Inspección también queda constatado que se había sustituido el sistema, no es menos cierto que el órgano experto en protección de datos, el Comité de delegados de protección de datos, del GRUPO SAICA, adquirente de la reclamada, determinó ya en 19/10/2022 la falta de aptitud de los datos biométricos para el fin del control laboral diario, y aconsejó de forma inmediata la sustitución del sistema de fichajes. También se ha de tener en cuenta que la reclamada conoció la reclamación, sus términos completos en sede del trámite de traslado, según consta en la recepción de 21/11/2022. Para ello, y mientras se implanta el nuevo, casi siete meses después, se siguen tratando los datos con tales medios para los 99 empleados. El cambio del sistema no es que no se tenga en cuenta ni se vaya a tener como atenuante de la infracción, sino que lo que constituye en todo caso agravante es el mantenimiento del anterior sistema, alargando sus efectos en tratamientos reiterados en el tiempo por periódicos, que no contienen una EIPD (tal como determina el tipo *“El tratamiento de datos personales sin haber llevado a cabo la evaluación del impacto de las operaciones de tratamiento en la protección de datos personales”*). Por otro lado, la sustitución del sistema para ser atenuada la circunstancia de la infracción no es ni más ni menos que cumplir la obligación de control horario laboral cumpliendo la normativa de protección de datos, lo cual no es sino una obligación general cuyo cumplimiento no puede ser recompensado cuando ha tenido lugar un plus de tratamiento desde que se decide que se debe abandonar el mismo, sumándose al ya largo período en que debió haber efectuado la citada EIPD.

Tampoco se explica que la citada sustitución guarda relación con el artículo 83.2.f) del RGPD, por cuanto aún no se había iniciado el procedimiento y la respuesta al requerimiento en actuaciones previas no supone per se cooperación, que también pudo haber tenido lugar con ocasión del traslado de la reclamación en la que se pusieron de manifiesto la reclamación con los hechos en sus términos. Tal cooperación con la autoridad de control no es ni constituye sino expresión de la obligación general impuesta por el RGPD citada en el artículo 58.1 del RGPD.

Finalmente, la mitigación de la infracción no puede suponer atenuante, si pudo dejar de usar el sistema en fechas próximas a octubre 2022, y sin embargo se alargó hasta 28/05/2023, manteniendo la falta de garantías del tratamiento cuando se debió haber mitigado en época más cercana de la primera fecha. A pesar del desarrollo de la planificación del nuevo sistema, para 99 empleados se podía haber usado una modalidad de transición que tuviera en cuenta los derechos de los empleados, y no se optó por dicha posibilidad.

Sobre la actuación que lleva a cabo SAICA como adquirente de la reclamada, se ha de indicar que la gestión de la misma no tiene como base, la fusión o absorción de la entidad que diera lugar al trasvase de la responsabilidad a SAICA. Por ello, el hecho de que el sistema ya estuviera implantado el 7/07/2022 cuando adquiere CB, no es suficiente para atenuar la responsabilidad de la reclamada, dado que, como nueva administradora de la reclamada, las decisiones tomadas que afectan a la reclamada son exigibles a la reclamada con independencia del acierto o prontitud y eficacia en la respuesta que la nueva administradora.

b) Se incluye una falta de diligencia grave, dado que preparó voluntariamente la implantación del sistema y no previó el impacto del mismo, por lo que este factor operaría

como agravante. (art 83.2.b RGPD).

Sobre la alegación de disconformidad de la reclamada con esta apreciación de falta de diligencia, al considerarla incluida en la tipificación de la infracción, se debe aclarar que el tipo describe el tratamiento sin haber efectuado una previa EIPD. En este caso, cabe indicar que pese a que no se tiene constancia de que la entidad haya obrado dolosamente, la actuación y el motivo de no haber actuado conforme a la normativa revela una falta de diligencia grave en su conducta que ha de agravar la infracción por su antijuridicidad. Ello se produce, al considerar la ausencia total del cumplimiento de un deber exigible desde la entrada en vigor del RGPD, sobre el que actuó como si no existiera normativa ni tal deber. Basa su no realización de tal instrumento de garantías del tratamiento que supone la EIPD, en la afirmación de que no le resultaba de aplicación el RGPD por la fecha en que implanta y comienza a funcionar el sistema, 2016. Esta declaración se efectúa, sin base documental o pericial especializada sobre la materia que hubiera extraído tal conclusión de forma razonada, siendo exigible por el principio de responsabilidad proactiva cumplir y demostrar el cumplimiento. En tal sentido, el mero hecho de que las condiciones que dan lugar a la obligación de llevar a cabo una EIPD considere la reclamada que no se hayan cumplido, no disminuye la obligación general de los responsables del tratamiento de justificar y documentar los motivos por los que no se realiza una EIPD.

Sin embargo, no consta que hubiera elaborado documento alguno en el que ese evaluara la necesidad o no de EIPD, teniendo en cuenta que la gestión del control horario diario del personal con el sistema biométrico se ha venido desarrollando sin solución de continuidad desde 2016. Se trata de una entidad que según los datos recogidos en el sector de su actividad es PYME, con un número medio de empleados, 99, y que debió apercebirse del cambio de modelo operado a efectos de protección de datos, al ser una rama más la del tratamiento de datos de recursos humanos que le afecta. Si se siguiera la lógica defendida en la manifestación para su no implantación de tal sistema, trasladable a otros aspectos de tales obligaciones impuestas por el RGPD (RAT, acreditación del cumplimiento documental de las medidas, protección de datos desde el diseño, análisis de riesgos) no se aplicaría ninguna de las obligaciones ni medidas a dichos tratamientos, o a otros que se vienen desarrollándose tiempo atrás, lo cual resulta inadmisibile desde el punto de vista del modelo que el RGPD implanta que pretende garantizar un alto nivel de protección de dichos datos. Así pues, se ha de confirmar la acreditada falta de diligencia grave.

En cuanto a la proporcionalidad sancionadora, con arreglo a estas circunstancias, la misma se entiende como la adecuación, según criterios de justicia y equidad, entre los hechos objeto del tipo infractor y la determinación de la sanción aplicable, teniendo en cuenta la intensidad de la culpa interviniente, esto es el grado de intencionalidad, descuido o negligencia que revele la conducta. Y desde luego, se exige una motivación sobre el juicio de intensidad de la culpa interviniente. Con lo que se enlazaría con lo preceptuado en el artículo 83.2 b) del RGPD.

Como consecuencia con los elementos que se disponen, se cuantifica la sanción en 200.000 euros.

En cuanto a la infracción del artículo 15 del RGPD, se ha de valorar:

- Cuando el solicitante insta su derecho, la entidad reclamada ya había sido adquirida por SAICA, que le remite al reclamante un primer escrito, indicando que se le va a responder,

pero no ha llevado a efecto de forma acreditada tal respuesta. En la reunión del CPD de 23/01/2023, se suscitó la cuestión del procedimiento para atender los derechos de acceso a datos personales, por lo cual, concurre la circunstancia agravante que determina el artículo 83.2 d) del RGPD: por la deficiente implantación del *“grado de responsabilidad del responsable o del encargado del tratamiento, habida cuenta de las medidas técnicas u organizativas que hayan aplicado en virtud de los artículos 25 y 32”*

-También se estima que concurre falta de diligencia que se intenta combatir en alegaciones por la reclamada con contactos telefónicos o por WhatsApp con objeto de citarle para supuestamente atender al ejercicio del derecho, entregándole la documentación, sin que se acredite dicha finalidad. No se le exige a la reclamada una actuación desproporcionada para el cumplimiento de la atención del derecho, sino la mínima. El hecho de que el reclamante no acuda a la empresa por petición de un asunto que no se acredita relacionado con la respuesta, y se le mande el escrito el 9/12/2022 a otra dirección, no a la que el reclamante consignó, sin que se acredite su recepción, muestra una falta de diligencia clara en el modo del cumplimiento del deber de atención de dicho derecho, que podía haber realizado de otro modo y ser efectivo. Luego, si se determina que concurrió falta de diligencia, resultando que se encuadraría como agravante en el artículo 83.2.b) del RGPD.

Sobre la alegación para esta infracción de que en el PS/00369/2022 se vulnera el principio de proporcionalidad al imponer la misma multa cuando aquel contaba con cuatro agravantes, se debe señalar que la naturaleza de los tratamientos son distintos, este procedimiento lo es sobre ejercicio de derecho de acceso a datos de la relación laboral, aquel era por infracción del artículo 17 del RGPD, y en consecuencia, al no otorgar el derecho, se siguieron tratando aquellos datos, como deudor y recibiendo mensajes sobre abono de su presunta deuda, con distintas circunstancias que no permiten acomodación en la comparación.

Sobre la alegación que en esta agravante, se emplea un mismo hecho para tipificar la infracción y aplicar la agravante, y a la vez se tipifica como muy grave, no como grave o leve, debe indicarse que los tipos propugnados para su aplicación por la reclamada, contenidos en los artículos 73.c) de la LOPDGDD, la grave, y 74.c) la leve, no se ajustan a la conducta que muestra la reclamada y por la que se ha tipificado, como se desprende de que la lectura del primero, refiere a casos en los que *“no se requiere la identificación del afectado, cuando este, para el ejercicio de esos derechos, haya facilitado información adicional que permita su identificación.”*, supuesto que no trata el caso presente. Igualmente, no se estima que sea calificable la conducta de leve, porque ya se ha detallado porque es aplicable el artículo 72.1.k) de la LOPDGDD.

Como consecuencia con los elementos que se disponen, se cuantifica la sanción en 20.000 euros.

En cuanto a las alegaciones de la reclamada sobre la falta de proporcionalidad en las sanciones que se prevén en el acuerdo de inicio, el RGPD expresa este principio en el artículo 83.2.1 (*“Cada autoridad de control garantizará que la imposición de las multas administrativas con arreglo al presente artículo por las infracciones del presente Reglamento indicadas en los apartados 4, 9 y 6 sean en cada caso individual efectivas, proporcionadas y disuasorias”*), añadiendo en el apartado 2 los criterios a tener en cuenta; por su parte, el artículo 76.2 b) especifica los factores atenuantes o agravantes a tener en cuenta, conforme al artículo 83.2 k) RGPD.

En este sentido, no se aprecia incongruencia con la entidad de las infracciones cometidas y las circunstancias de los hechos conocidas, el grado de antijuridicidad y la actitud de la reclamada conocida la reclamación desde que se produjo el traslado.

Por lo demás, la proporcionalidad sancionadora se entiende como la adecuación, según criterios de justicia y equidad, entre los hechos objeto del tipo infractor y la determinación de la sanción aplicable, teniendo en cuenta la intensidad de la culpa interviniente, esto es el grado de intencionalidad, descuido o negligencia que revele la conducta. Y desde luego, se exige una motivación sobre el juicio de intensidad de la culpa interviniente, que aquí ha sido detallada. Asimismo, considerando que las cuantías podrían ascender de conformidad con el artículo 83.4.a) y 83.5.a) del RGPD que prevé para la infracción del artículo 35 y 12 del RGPD multas administrativas de 10.000.000 € y 20.000.000 € como máximo o, tratándose de una empresa, de una cuantía equivalente al 2% o el 4% respectivamente como máximo del volumen de negocio total anual global del ejercicio financiero anterior, optándose por la de mayor cuantía, y constando un importe neto de cifra de negocios de (...) €. en 2021, último ejercicio presentado.

En cuanto a las alegaciones del tratamiento distinto en las cuantías de las infracciones, que se ha efectuado, dando datos de tres expedientes, no sería posible comparar los casos, dado que la naturaleza, ámbito, contexto y fines del tratamiento son distintos en cada procedimiento.

Si bien, se debe significar, sobre la alegación de la desigual cuantía sancionadora por la infracción del mismo artículo, comparación con el caso (...), expediente PS/00XXX/20XX y el volumen de negocio que indica, así como la sanción por la infracción del artículo 35 que en aquel se impuso, se debe indicar que sí que existía EIPD como se puede deducir de la lectura en el que incluso se analizan sus términos. HECHO SEGUNDO, puntos 6 y 7 entre otros.

En el presente supuesto, a pesar de que desde 2018 con la entrada en vigor del RGPD se instaaura un régimen de protección de datos que establece nuevas obligaciones para los responsables, enfocado a las garantías del cumplimiento de las obligaciones impuestas, “*compliance*” con el desarrollo del principio nuevo de responsabilidad proactiva y la gestión y el análisis de los riesgos para los derechos y libertades de las personas que supone un tratamiento de datos el análisis de riesgos para los derechos y libertades fundamentales El sistema de medidas de responsabilidad proactivas incluye obligaciones generales como la protección de datos desde el diseño y por defecto, medidas de seguridad y Evaluación de Impacto sobre la Protección de datos, y catalogó como categoría especial los datos biométricos, en el que los riesgos para los derechos y libertades fundamentales para la protección de datos y el tratamiento de los mismos a través de cumplimiento de las obligaciones generales es imperativo.

Sobre la alegación de que la reclamada fue adquirida por SAICA PACK el 7/07/2022 una vez instalado el sistema, y considera que tomó acciones para evitar el empleo del sistema instalado, considerando se debía atenuar con base al artículo 83.2.b).

En tal sentido, la nueva adquirente, sin que la entidad originaria haya desaparecido, no se deduce que ha cumplido diligentemente cuando en la valoración de cada infracción se ha razonado que no fue tal el caso. Además, en ninguna de las actuaciones en cuanto al cese de sus efectos tuvo una acción efectiva y decisiva la adquirente de CB, por cuanto los efectos de

las infracciones fueron más allá de lo razonable, con independencia del cambio de sistema de fichaje y el tiempo que lleva acometerlo.

Finalmente, en cuanto a la no aplicación de las letras b), c), e) f) del artículo 76 de la LOPDGDD, se ha de indicar:

-en la letra b), el hecho de que su principal actividad no aparezca ligada directamente al tratamiento de datos como pudieran ser a título de ejemplo, las entidades empresariales, las financieras u operadores de telecomunicaciones, no ha de servir como acicate o beneficio para una eventual reducción en la sanción a la que no se ha hecho merecedor, entendiendo que por no participar en el tráfico habitual y diario del mercado de datos personales no va a afectar proporcionalmente a la gravedad del hecho infractor. De hecho, es difícil precisar una actividad o sector que no conlleve la realización de tratamientos de datos en mayor o menor medida y con diferentes alcances. La reclamada es una organización empresarial que gestiona datos catalogados como de categoría especial, con finalidad de control laboral diario, lo que supone que, según manifiesta, la extensión en el tiempo y la frecuencia es alta. De ello, la reclamada ha de asumir el riesgo de que los mismos puedan ser tratados de manera contraria a la ley. Contemplar la vinculación de la actividad del infractor con la eventual o supuesta escasa realización de tratamientos de datos como atenuante, no puede sino anular el efecto disuasorio de la multa, minorando por defecto las circunstancias que puedan concurrir, lo que sería tanto como considerar que el no tratamiento habitual de datos o la falta de vinculación de la actividad del infractor con la realización de tratamientos de datos, pudiera no producir efectos negativos, sino más bien positivos, preconfigurando la circunstancia atenuante sin considerar caso a caso los elementos que concurren, como en este caso. Con su efecto disuasorio, las multas administrativas contribuyen a reforzar la protección de las personas físicas en lo que respecta al tratamiento de datos personales y constituyen, por ende, un elemento clave para garantizar el respeto de los derechos de dichas personas, de conformidad con la finalidad del citado Reglamento de asegurar un elevado nivel de protección de esas personas en lo que respecta al tratamiento de los datos personales. Como conclusión, no se estima que concorra esta atenuante en la conducta de la reclamada.

-Sobre la letra c), las infracciones cometidas no exigen que se produzca un beneficio a favor del infractor. Sobre la falta de beneficios obtenidos en el tratamiento de los datos objeto de reclamación, como atenuante, este criterio de graduación se establece en la LOPDGDD, de acuerdo con lo previsto en el artículo 83.2.k) del RGPD, según el cual las multas administrativas se impondrán teniendo en cuenta cualquier *“factor agravante o atenuante aplicable a las circunstancias del caso, como los beneficios financieros obtenidos o las pérdidas evitadas, directa o indirectamente, a través de la infracción”*, entendiéndose que evitar una pérdida tiene la misma naturaleza a estos efectos que la obtención de beneficios. Si a esto añadimos que las sanciones deberán ser *“en cada caso individual” efectivas, proporcionadas y disuasorias*, conforme a lo previsto en el artículo 83.1 del RGPD, admitir la ausencia de beneficios como una atenuante, no solo es contrario a los presupuestos de hechos contemplados en el artículo 76.2.c), sino también contrario a lo establecido en el artículo 83.2.k) del RGPD y a los principios señalados. Así, valorar la ausencia de beneficios como una atenuante anularía el efecto disuasorio de la multa, en la medida en que minoraría el efecto de las circunstancias que inciden efectivamente en su cuantificación, reportando al responsable un beneficio al que no se ha hecho merecedor. Sería una rebaja artificial de la sanción que puede llevar a entender que infringir la norma sin obtener beneficios, financieros o del tipo que fuere, *“no le producirá un efecto negativo proporcional a la gravedad del hecho infractor”*. Se ha de sumar, que *“En todo caso, las multas administrativas establecidas en el*

RGPD, conforme a lo establecido en su artículo 83.2, se imponen en función de las circunstancias de cada caso individual”, y, en el presente, no se estima que la ausencia de beneficios sea un factor de graduación adecuado y determinante para valorar la gravedad de la conducta infractora. Solo en el caso de que esta ausencia de beneficios sea relevante para determinar el grado de antijuricidad y de culpabilidad presentes en la concreta actuación infractora podrá considerarse como un atenuante, en aplicación del artículo 83.2.k) del RGPD, que se refiere a “cualquier otro factor agravante o atenuante aplicable a las circunstancias del caso”. Este párrafo deja una puerta abierta a aquellos supuestos en que la ausencia de beneficios pueda ser considerado circunstancia atenuante, mas no a tenor de la interpretación literal y teleológica del legislador conforme a la previsión del art. 83.2.k) del RGPD.

-Sobre la letra e), pues si bien no se llevó a cabo un proceso de absorción, sí que se adquirió el 98,52% de las acciones de CARTONAJES BAÑERES. La adquisición o control de la entidad reclamada, que fue la que disponía del sistema previamente implantado, debió conocer la existencia de tal sistema cuando fue adquirida, y si bien tomó el control de dicha entidad, también comenzó la dirección y gestión de la misma, sin que tal dirección, aparte de no encuadrarse en dicha o absorción, hubiera sido decisiva para la corrección o mitigación de los efectos producidos.

-Sobre la letra f) por no tratar datos de menores, debe considerarse que el tratamiento de tales datos puede constituir en su caso un agravante, pero el hecho de que no se traten tales datos en sí mismos, no constituye un atenuante, sin que, por otra parte, el responsable del tratamiento justifique en modo alguno porque debe ser tenido en cuenta en este sentido tal circunstancia.

En cuanto a la alegación última que indica tras exponer las circunstancias sobre la falta de proporcionalidad que se declare la nulidad según el artículo 47.1.e) de la LPACAP o subsidiariamente anulable según el artículo 48 de la misma Ley, tales motivos, por el hecho de no respetar en su caso el principio de la proporcionalidad de las cuantías sancionadoras, no se encuentran entre las razones que pueden propiciar la nulidad o anulabilidad. Por otro lado, no razona que motivo contribuiría a su juicio a cada una de las peticiones, por lo que la alegación no puede ser aceptada.

X Adopción de medidas

El artículo 58.2 del RGPD dispone lo siguiente: “Cada autoridad de control dispondrá de todos los siguientes poderes correctivos indicados a continuación:

“c) ordenar al responsable o encargado del tratamiento que atiendan las solicitudes de ejercicio de los derechos del interesado en virtud del presente Reglamento;

“

i) imponer una multa administrativa con arreglo al artículo 83, además o en lugar de las medidas mencionadas en el presente apartado, según las circunstancias de cada caso particular;”

La imposición de cualquiera de estas medidas es compatible con la sanción consistente en multa administrativa, según lo dispuesto en el art. 83.2 del RGPD.

Considerando que el ejercicio de derecho de acceso del reclamante no ha sido atendido, conforme a las pautas que se contienen en el análisis de su respectiva infracción, como medida a adoptar se habrá de atender completamente la solicitud de ejercicio de derecho del interesado para lo que deberá agotar las vías de comunicación en su día ofrecidas contenidas en la petición, cumpliendo con el envío y acreditando la recepción o puesta a disposición de la atención del citado derecho.

A la vista de lo expuesto se procede a emitir la siguiente

Por lo tanto, de acuerdo con la legislación aplicable y valorados los criterios de graduación de las sanciones cuya existencia ha quedado acreditada,
la Directora de la Agencia Española de Protección de Datos,

RESUELVE:

PRIMERO: IMPONER a **CARTONAJES BAÑERES, S.A.** con NIF **A03009263** dos multas administrativas por la infracción de los siguientes artículos del RGPD:

- Artículo 35, de conformidad con el artículo 83.4 a) del RGPD, y a efectos de prescripción de la infracción, calificada como grave en el artículo 73.t) de la LOPDGDD, con 200.000 euros
- Artículo 15, de conformidad con el artículo 83.5 b) del RGPD, y a efectos de prescripción de la infracción, calificada como muy grave en el artículo 72.1.k) de la LOPDGDD, con 20.000 euros.

SEGUNDO: ORDENAR a **CARTONAJES BAÑERES, S.A.** con NIF **A03009263** que en virtud del artículo 58.2.c) del RGPD, que en el plazo de 30 días desde que la resolución que ponga fin a este procedimiento sea ejecutiva, acredite haber atendido al cumplimiento del ejercicio del derecho de acceso del reclamante.

TERCERO: NOTIFICAR la presente resolución a **CARTONAJES BAÑERES, S.A.**

CUARTO: Esta resolución será ejecutiva una vez finalice el plazo para interponer el recurso potestativo de reposición (un mes a contar desde el día siguiente a la notificación de esta resolución) sin que el interesado haya hecho uso de esta facultad. Se advierte al sancionado que deberá hacer efectiva la sanción impuesta una vez que la presente resolución sea ejecutiva, de conformidad con lo dispuesto en el art. 98.1.b) de la ley 39/2015, de 1/10, del Procedimiento Administrativo Común de las Administraciones Públicas (en adelante LPACAP), en el plazo de pago voluntario establecido en el art. 68 del Reglamento General de Recaudación, aprobado por Real Decreto 939/2005, de 29 de julio, en relación con el art. 62 de la Ley 58/2003, de 17/12, mediante su ingreso, indicando el NIF del sancionado y el número de procedimiento que figura en el encabezamiento de este documento, en la cuenta restringida nº **IBAN: ES00-0000-0000-0000-0000-0000 (BIC/Código SWIFT: CAIXESBBXXX)**, abierta a nombre de la Agencia Española de Protección de Datos en la entidad bancaria CAIXABANK, S.A.. En caso contrario, se procederá a su recaudación en período ejecutivo.

Recibida la notificación y una vez ejecutiva, si la fecha de ejecutividad se encuentra entre los días 1 y 15 de cada mes, ambos inclusive, el plazo para efectuar el pago voluntario será hasta el día 20 del mes siguiente o inmediato hábil posterior, y si se encuentra entre los días 16 y último de cada mes, ambos inclusive, el plazo del pago será hasta el 5 del segundo mes siguiente o inmediato hábil posterior.

De conformidad con lo establecido en el artículo 50 de la LOPDGDD, la presente Resolución se hará pública una vez haya sido notificada a los interesados.

Contra esta resolución, que pone fin a la vía administrativa conforme al art. 48.6 de la LOPDGDD, y de acuerdo con lo establecido en el artículo 123 de la LPACAP, los interesados podrán interponer, potestativamente, recurso de reposición ante la Directora de la Agencia Española de Protección de Datos en el plazo de un mes a contar desde el día siguiente a la notificación de esta resolución o directamente recurso contencioso administrativo ante la Sala de lo Contencioso-administrativo de la Audiencia Nacional, con arreglo a lo dispuesto en el artículo 25 y en el apartado 5 de la disposición adicional cuarta de la Ley 29/1998, de 13/07, reguladora de la Jurisdicción Contencioso-administrativa, en el plazo de dos meses a contar desde el día siguiente a la notificación de este acto, según lo previsto en el artículo 46.1 de la referida Ley.

Finalmente, se señala que conforme a lo previsto en el art. 90.3 a) de la LPACAP, se podrá suspender cautelarmente la resolución firme en vía administrativa si el interesado manifiesta su intención de interponer recurso contencioso-administrativo. De ser éste el caso, el interesado deberá comunicar formalmente este hecho mediante escrito dirigido a la Agencia Española de Protección de Datos, presentándolo a través del Registro Electrónico de la Agencia [<https://sedeagpd.gob.es/sede-electronica-web/>], o a través de alguno de los restantes registros previstos en el art. 16.4 de la citada LPCAP. También deberá trasladar a la Agencia la documentación que acredite la interposición efectiva del recurso contencioso-administrativo. Si la Agencia no tuviese conocimiento de la interposición del recurso contencioso-administrativo en el plazo de dos meses desde el día siguiente a la notificación de la presente resolución, daría por finalizada la suspensión cautelar.

938-16012024

Mar España Martí
Directora de la Agencia Española de Protección de Datos